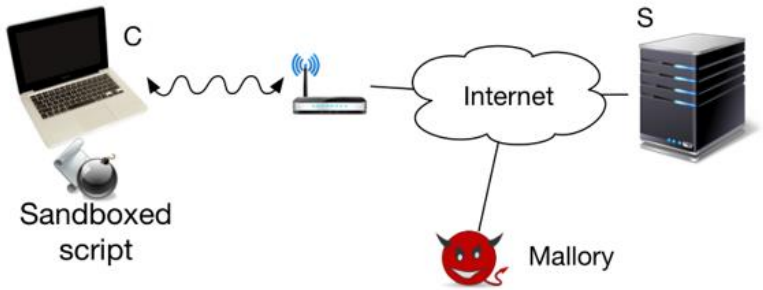
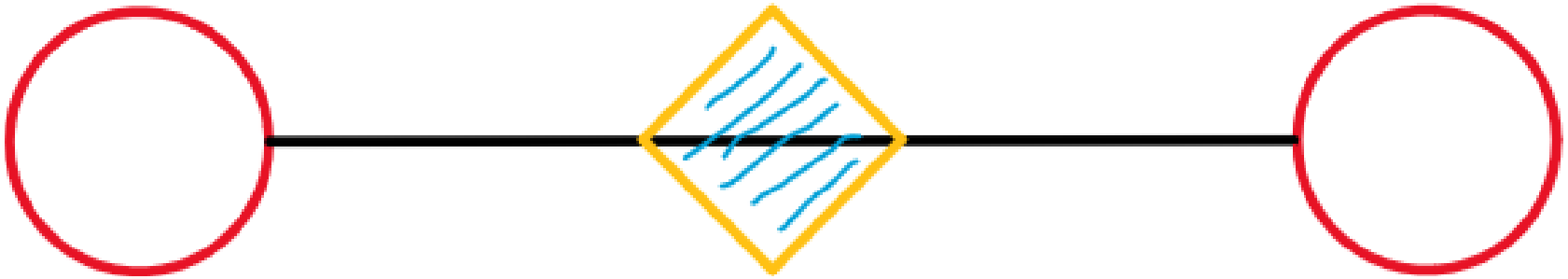
Off-Path TCP Exploit: How **Wireless Routers** Can Jeopardize Your Secrets



Weiteng Chen, Zhiyun Qian

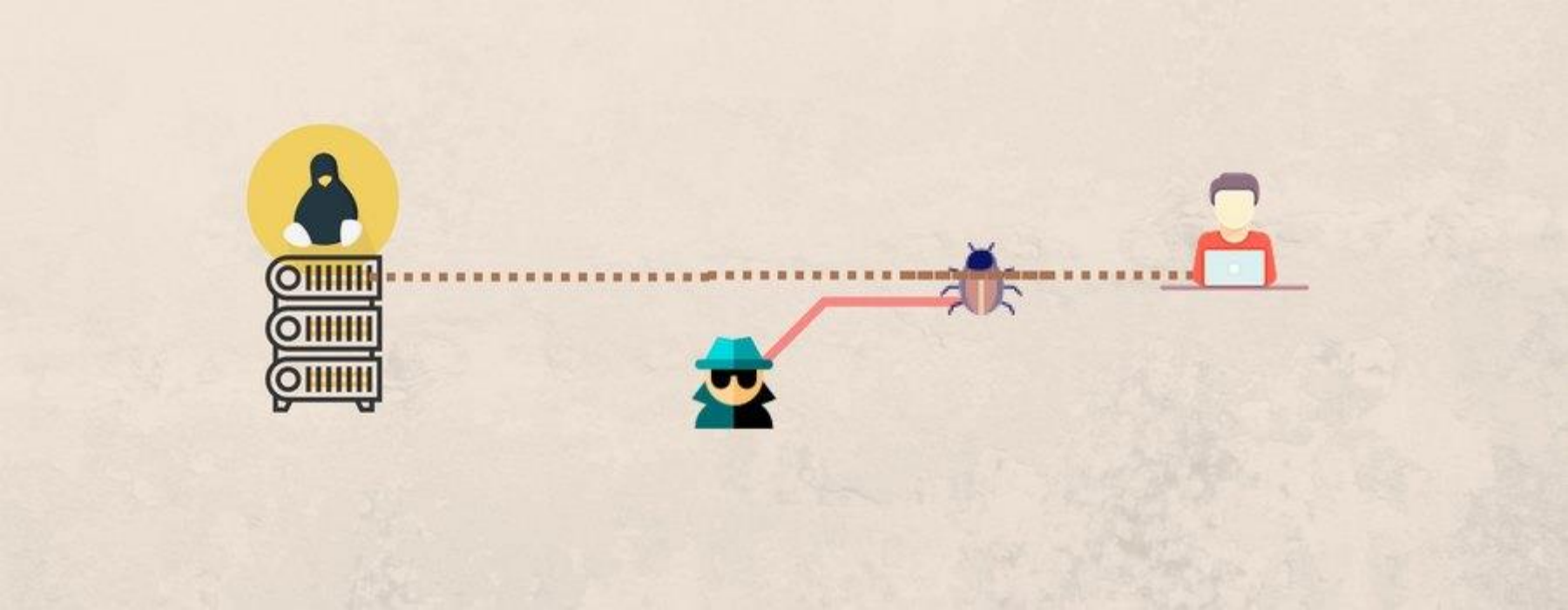
University of California, Riverside

Man-in-the-middle attack



Off-Path TCP Exploit

All existing vulnerabilities related to off-path TCP exploit essentially stem from software artifacts. The ones that can lead to serious attacks are already patched primarily by (1) eliminating the shared resources in protocol implementations (or adding randomness to them) [7, 8] and (2) reducing the opportunities that the shared resources leak information, *e.g.*, employing a more stringent acknowledge(ACK) number check [44]). As we will discuss later in §2.3, almost all previously reported off-path TCP attacks no longer work.



Side channels

WIKIPEDIA
The Free Encyclopedia

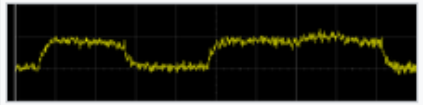
Side-channel attack

From Wikipedia, the free encyclopedia

In computer security, a **side-channel attack** is any attack based on information gained from the implementation of a computer system, rather than weaknesses in the implemented algorithm itself (e.g. cryptanalysis and software bugs). Timing information, power consumption, electromagnetic leaks or even sound can provide an extra source of information, which can be exploited.

Some side-channel attacks require technical knowledge of the internal operation of the system, although others such as differential power analysis are effective as black-box attacks. The rise of Web 2.0 applications and software-as-a-service has also significantly raised the possibility of side-channel attacks on the web, even when transmissions between a web browser and server are encrypted (e.g. through HTTPS or WiFi encryption), according to researchers from Microsoft Research and Indiana University.[1] Many powerful side-channel attacks are based on statistical methods pioneered by Paul Kocher.[2]

Attempts to break a cryptosystem by deceiving or coercing people with legitimate access are not typically considered side-channel attacks: see social engineering and rubber-hose cryptanalysis.



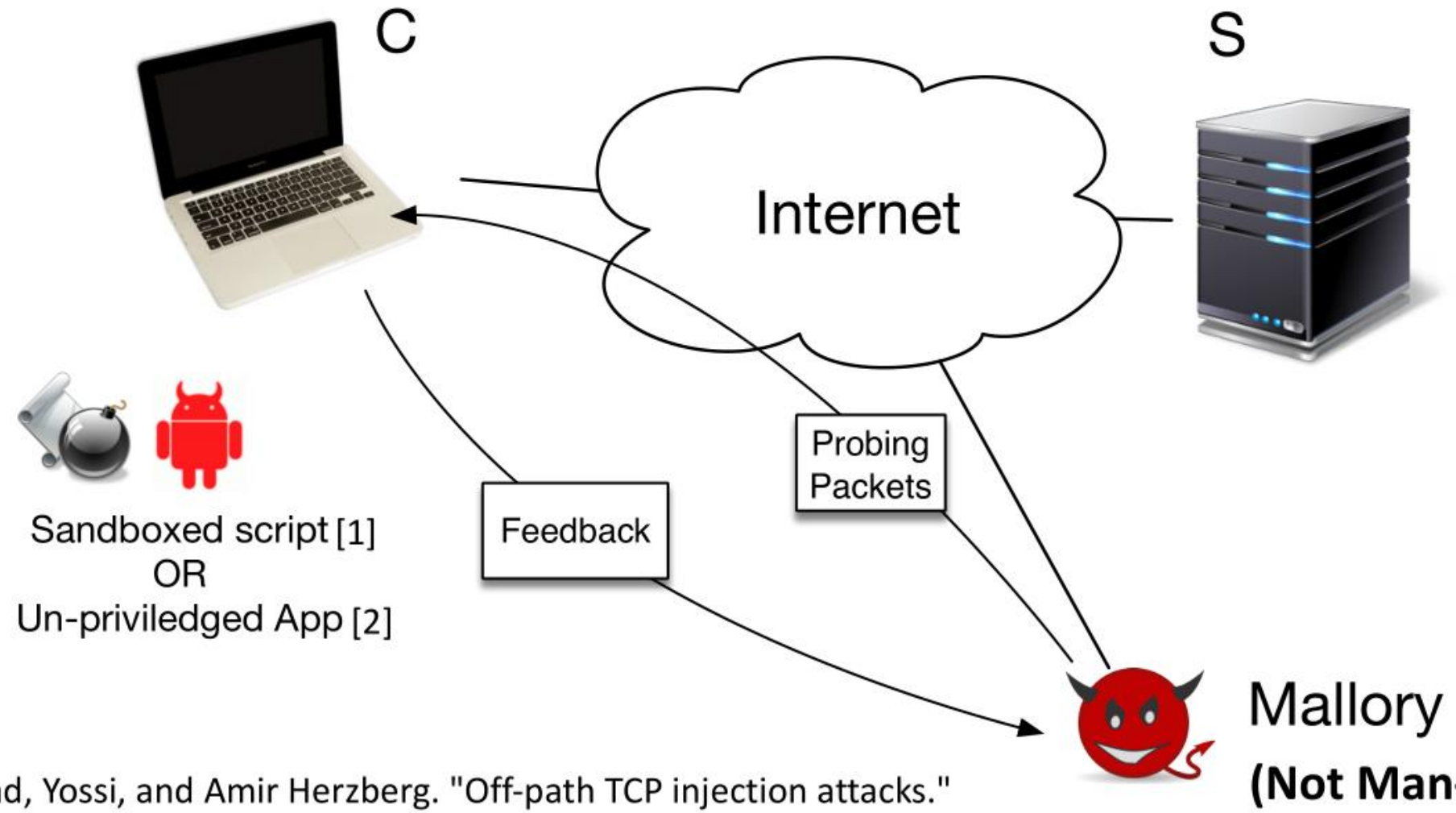
An attempt to decode RSA key bits using power analysis. The left peak represents the CPU power variations during the step of the algorithm without multiplication, the right (broader) peak – step with multiplication, allowing an attacker to read bits 0, 1.

Contents [hide]

1 General
2 Examples
3 Countermeasures
6.2 Articles
7 External links

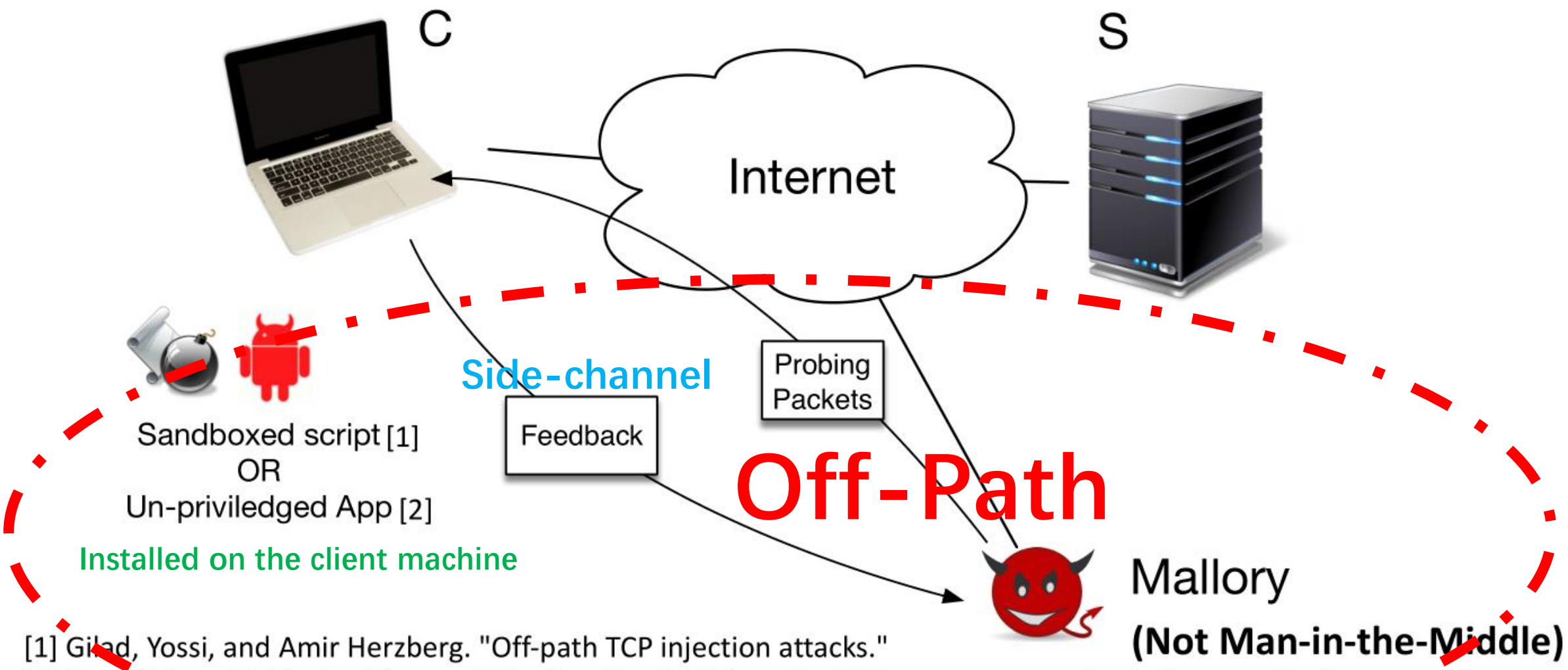
any attack based on information gained from the implementation of a computer system,

Generic Threat Model



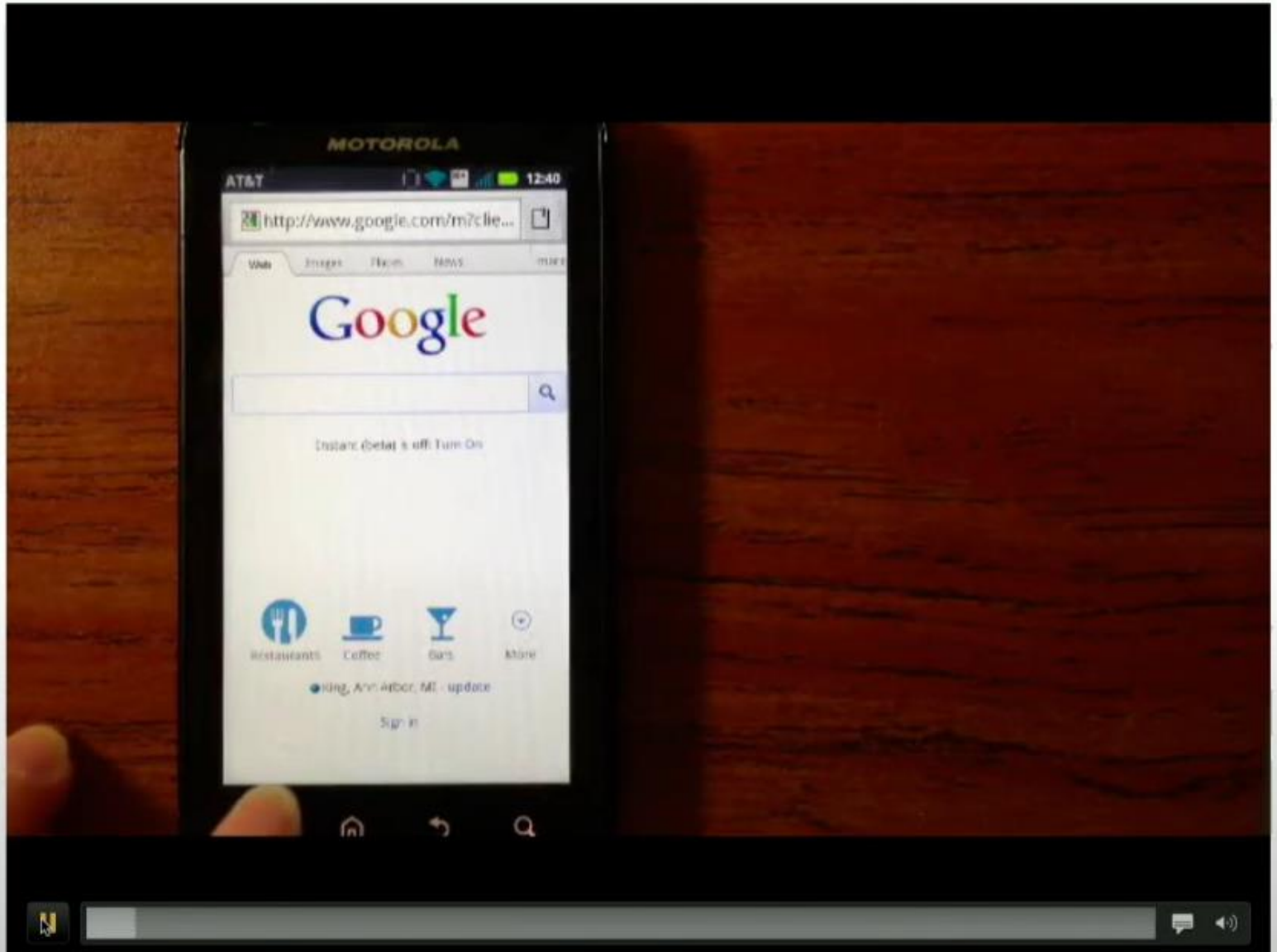
[1] Gilad, Yossi, and Amir Herzberg. "Off-path TCP injection attacks."
[2]Qian, Zhiyun, Z. Morley Mao, and Yinglian Xie. "Collaborative TCP sequence number inference attack: how to crack sequence number under a second."

Generic Threat Model

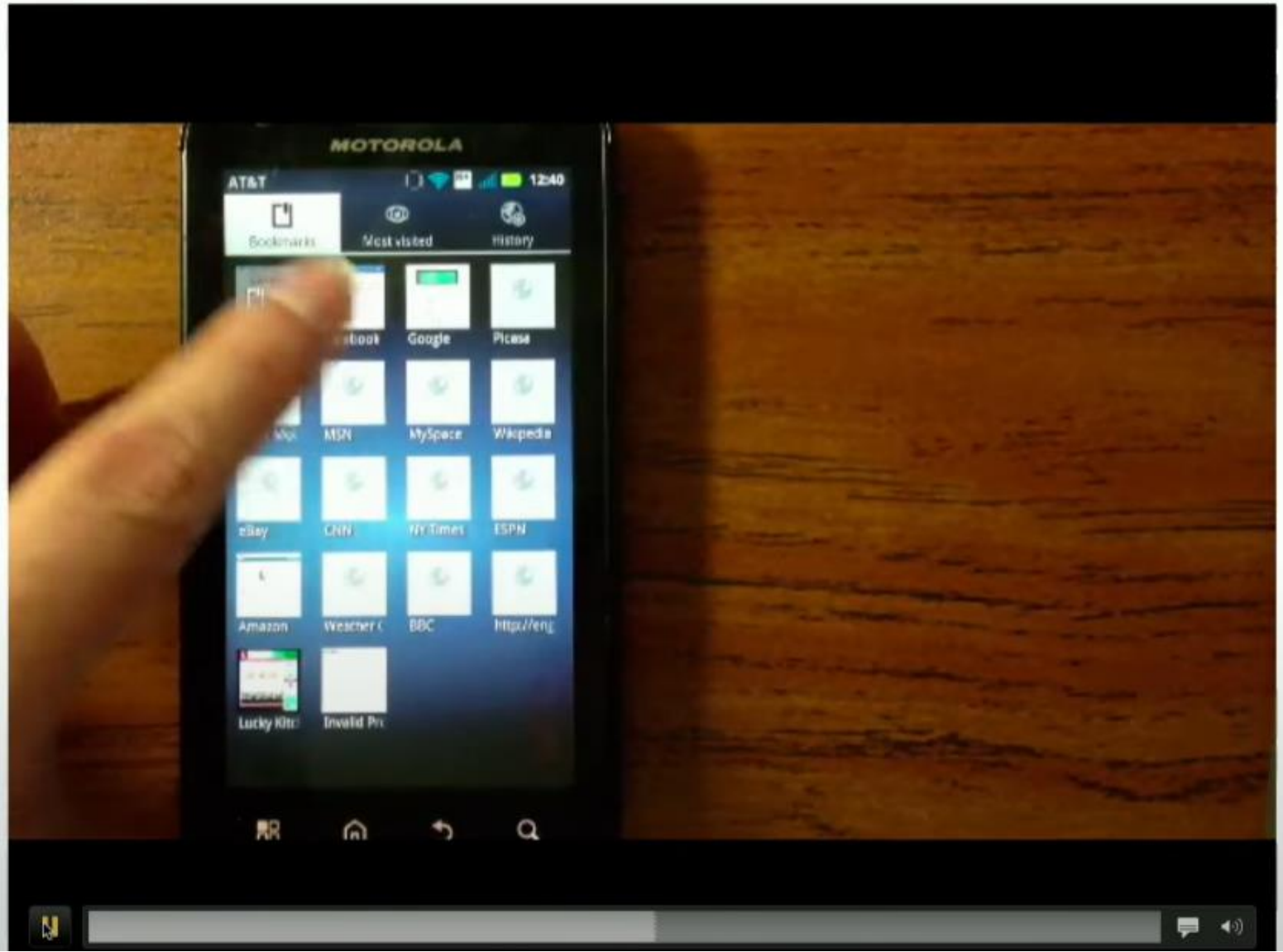


[1] Gilad, Yossi, and Amir Herzberg. "Off-path TCP injection attacks."
[2]Qian, Zhiyun, Z. Morley Mao, and Yinglian Xie. "Collaborative TCP sequence number inference attack: how to crack sequence number under a second."

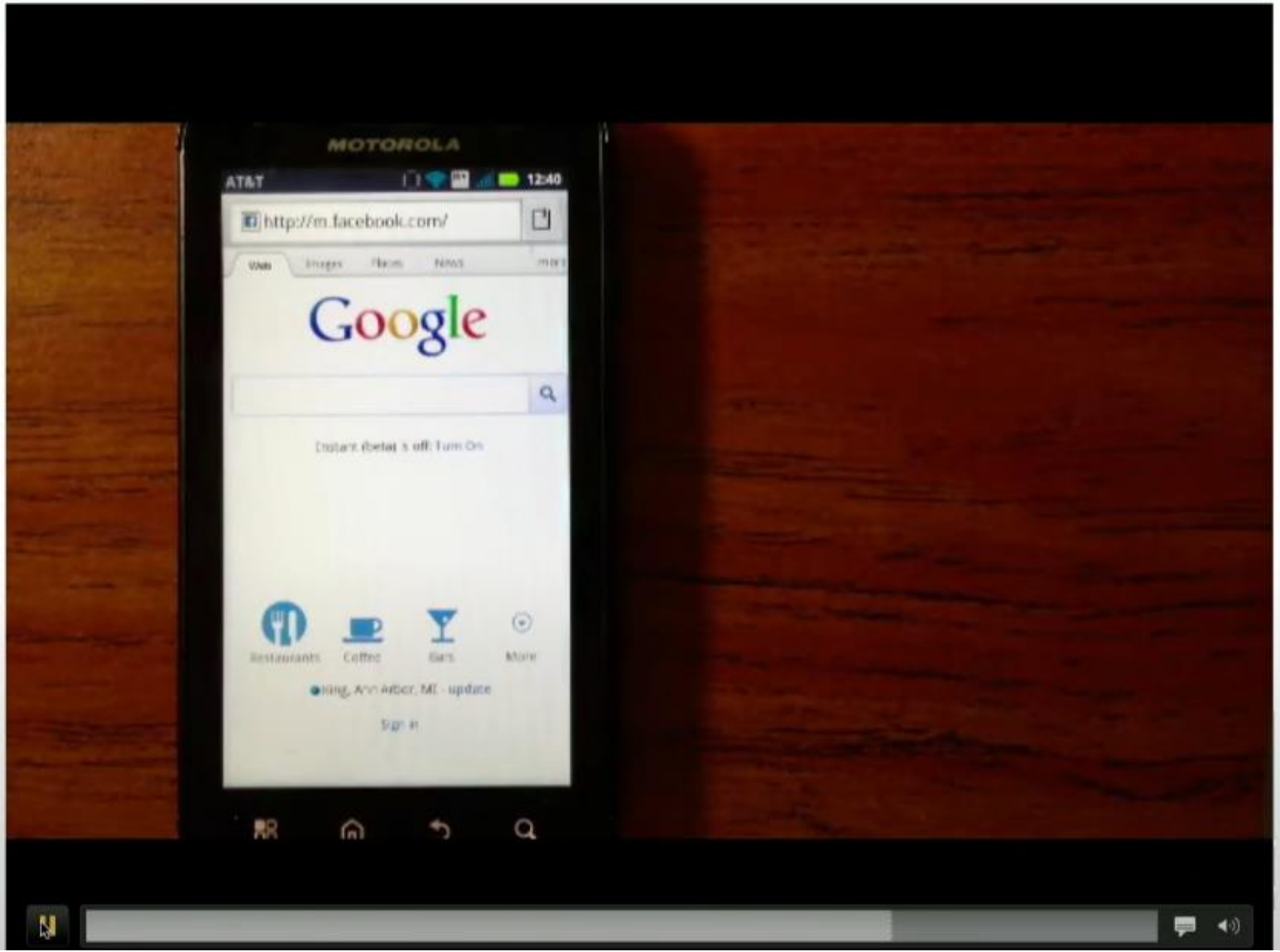
An attack using packet counter side channel



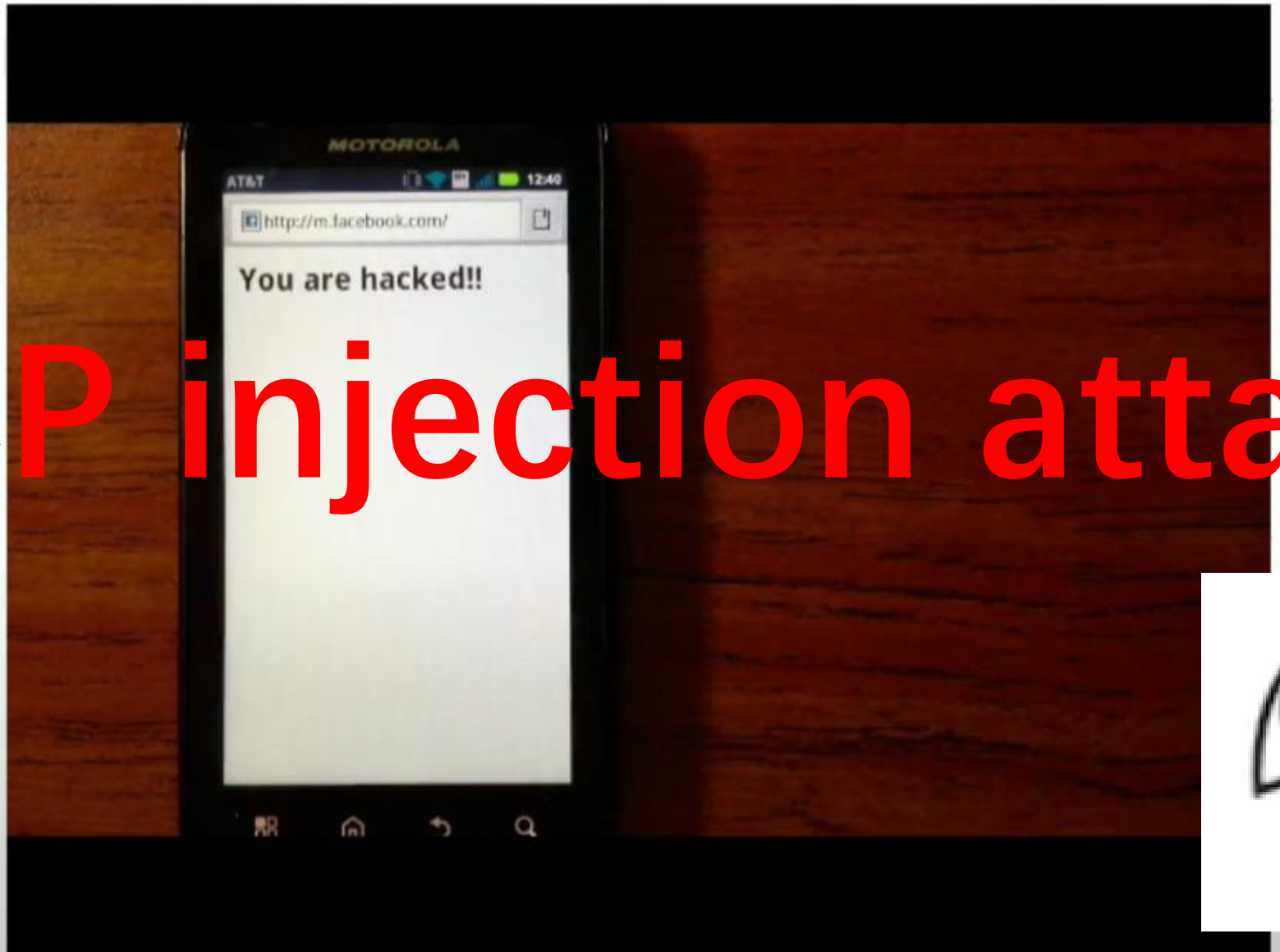
An attack using packet counter side channel



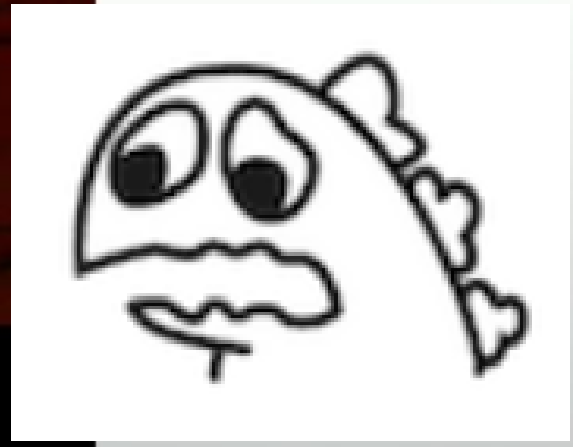
An attack using packet counter side channel



An attack using packet counter side channel



TCP injection attack



Building Blocks of Side Channels

```
if (in_packet.seq is in rcv_window)
    // shared state change 1
else
    // shared state change 2
```

outcome of the comparison, the shared state may change to different values. The change also has to be observable by the attacker through some side channel. Two necessary building blocks are needed in a TCP off-path side channel attack: (1) existence of vulnerable packet validation logic; (2) the shared state has to be observable by an attacker (*i.e.*, the sandboxed script, unprivileged app, or the off-path attacker). Note that together these two building blocks result in a violation of the non-interference property [29, 50].

- Shared resources
  - e.g., Global IP-ID counter, Packet counter, Global challenge ACK rate limit
- Shared state changes observable to attackers
  - e.g., Javascript, Un-priviledged Malware

A Time-Line of TCP Injection Attacks

Defenses

Unpredictable ISN
[RFC1948 1996]

Minimize ACK
window
[RFC5961 2010]

Predict

Attacks

[Morris 1985] [Bellovin 1989]

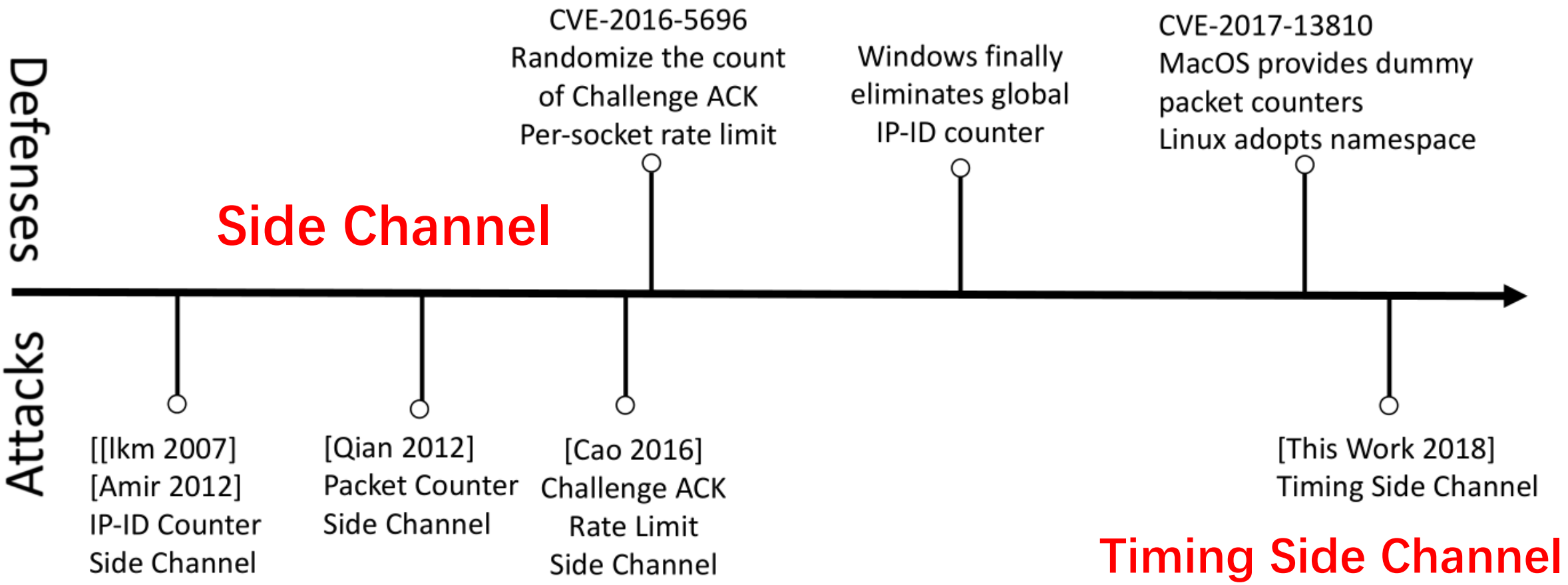
Exploit Predictable ISNs
(Initial Sequence Number)

[Watson 2004]
Blind Reset
Attacks

Brute Force

[Gilad 2014]
Blind Data Injection

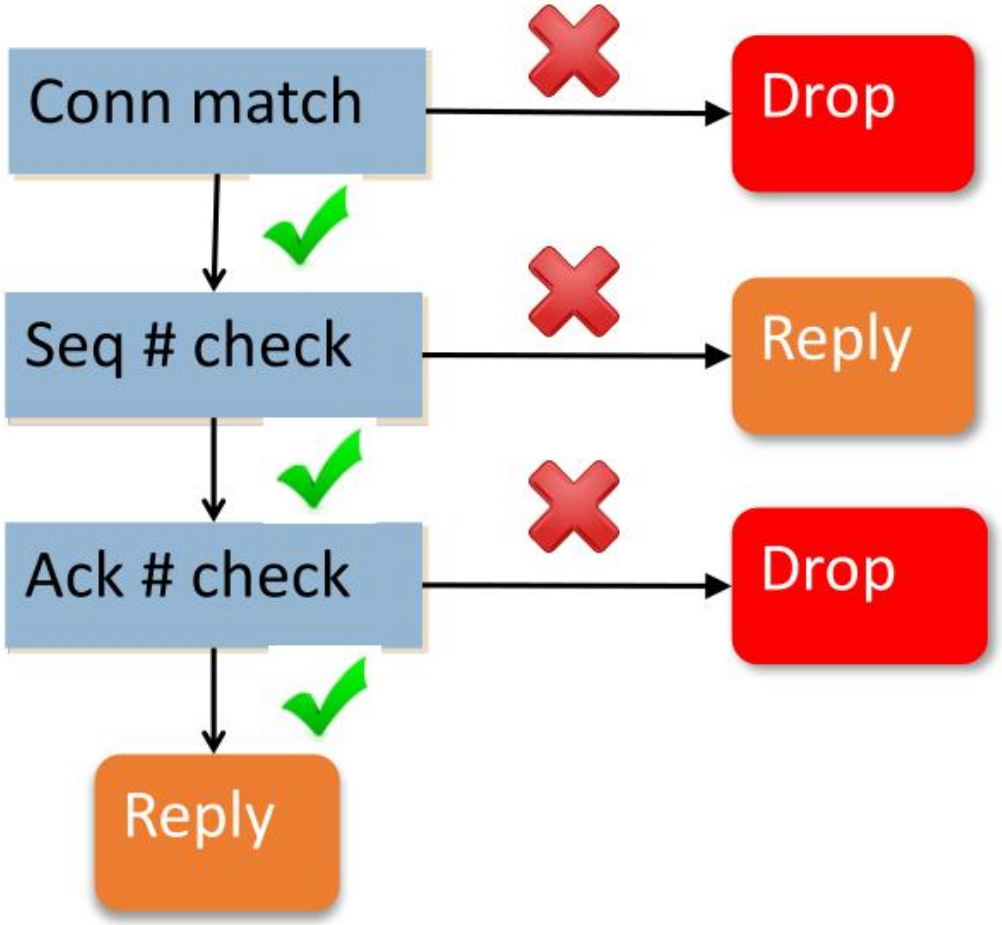
A Time-Line of TCP Injection Attacks (Cont)



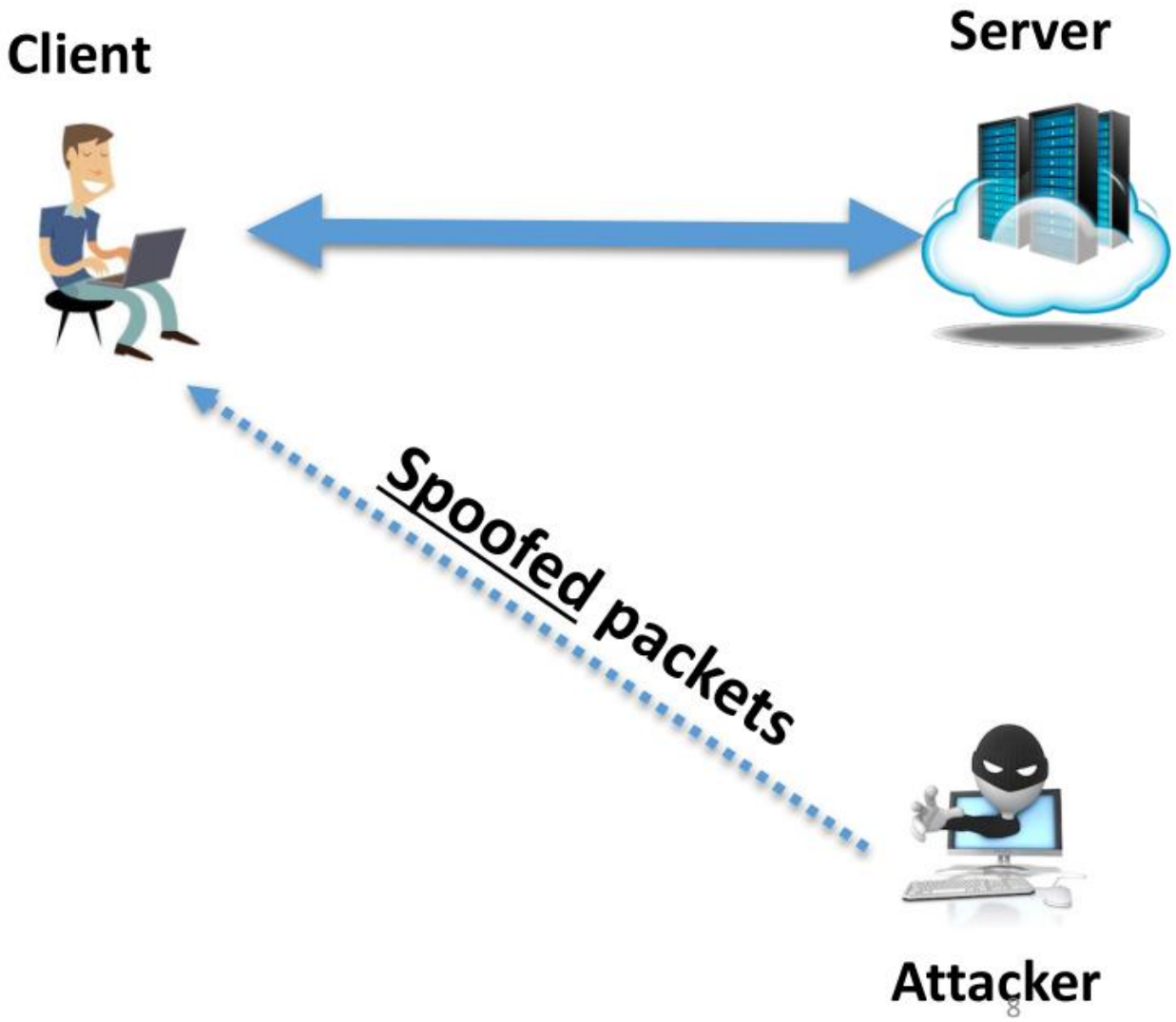
Off-Path TCP Injection Attacks

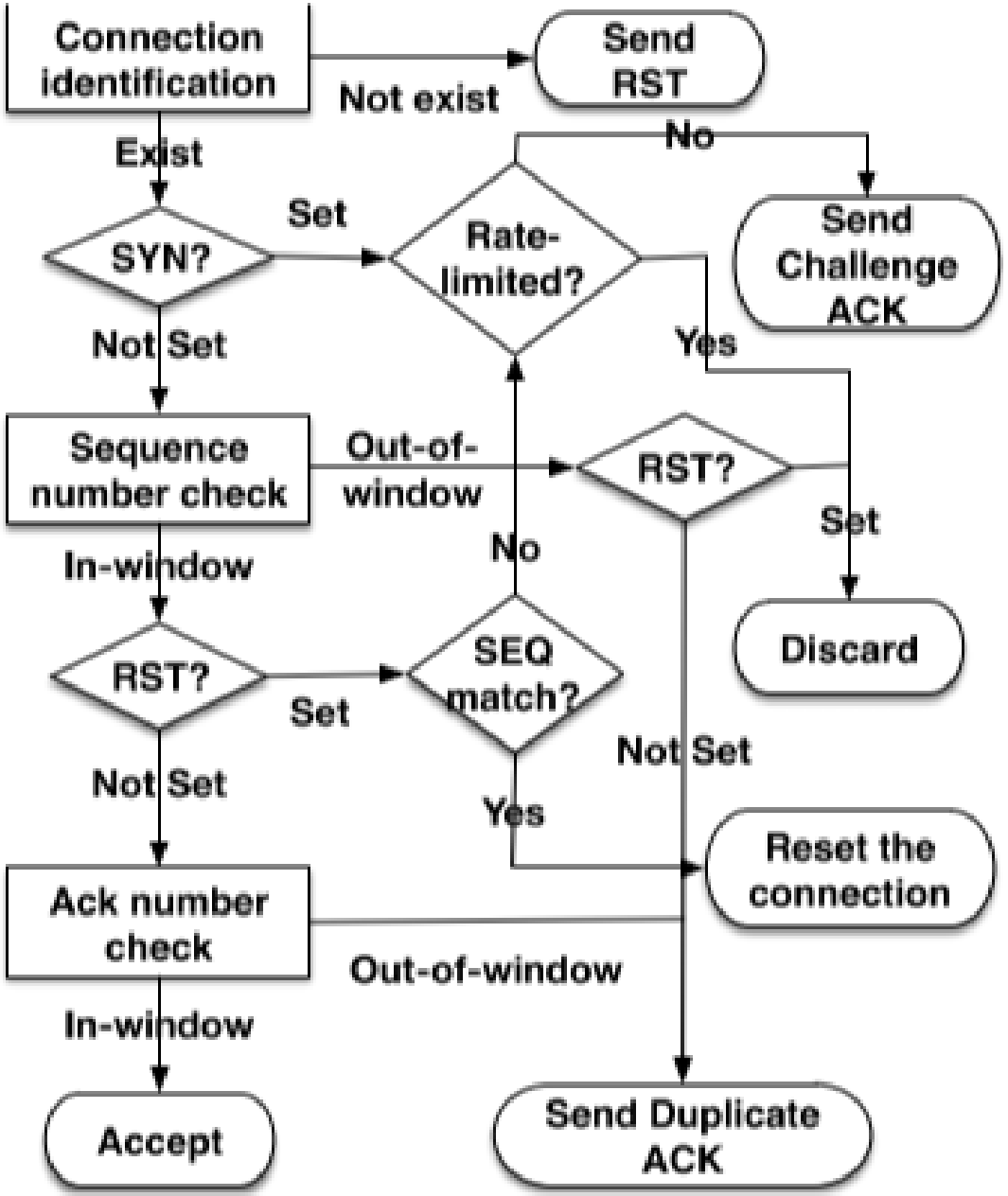
Side Channel	Requirement	Affected OS	Patch/Mitigation
Global IP-ID counter	N/A	Windows	Global IPID counter eliminated
Global challenge ACK rate limit	N/A	Linux	Global rate limit eliminated
Packet counter	Malware	Linux, MacOS	Namespace/dummy counter
Wireless contention (this work)	Javascript	Any	N/A

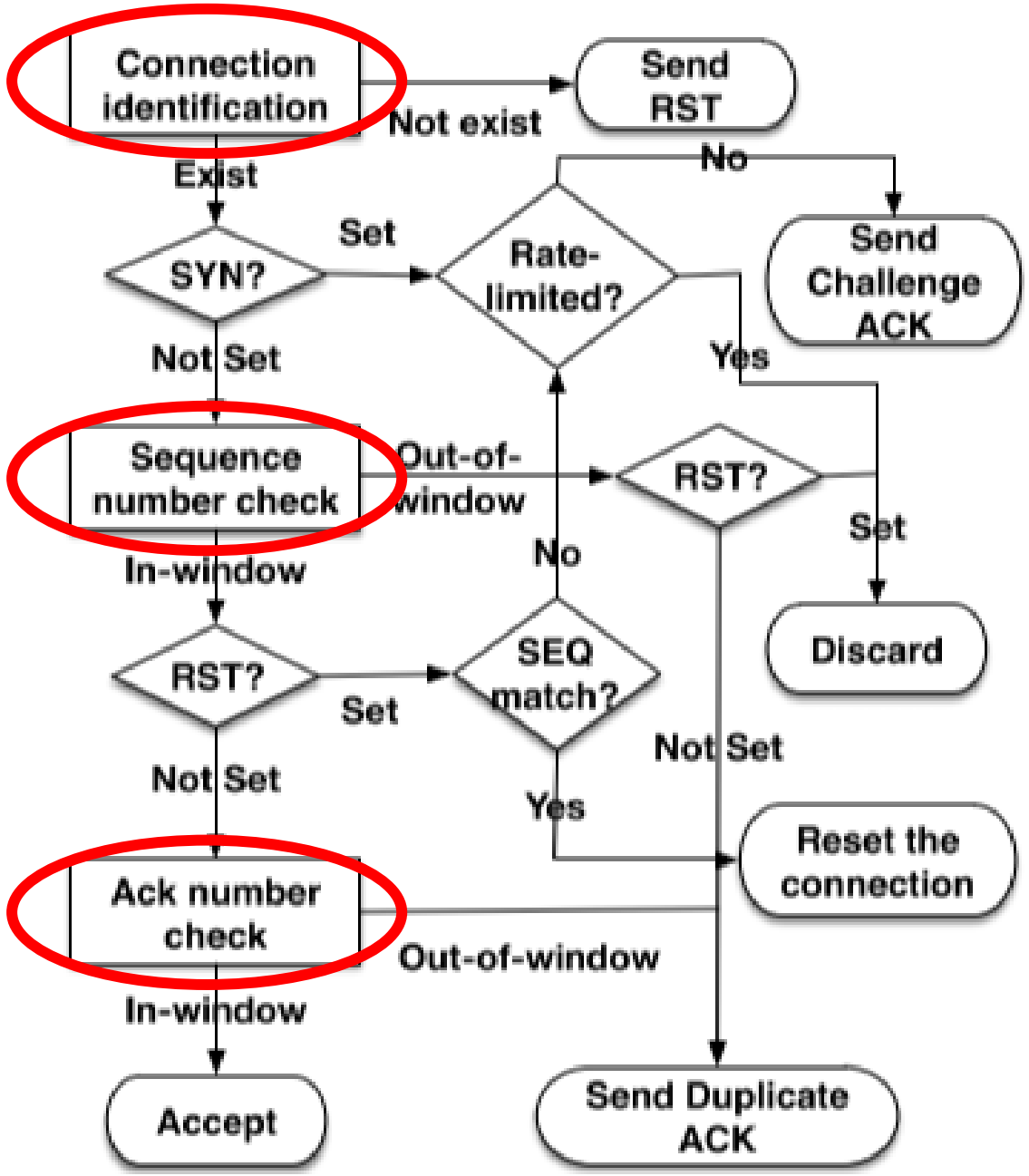
RFC 793: TCP Packet Receiving Basics



Simplified Processing Logic

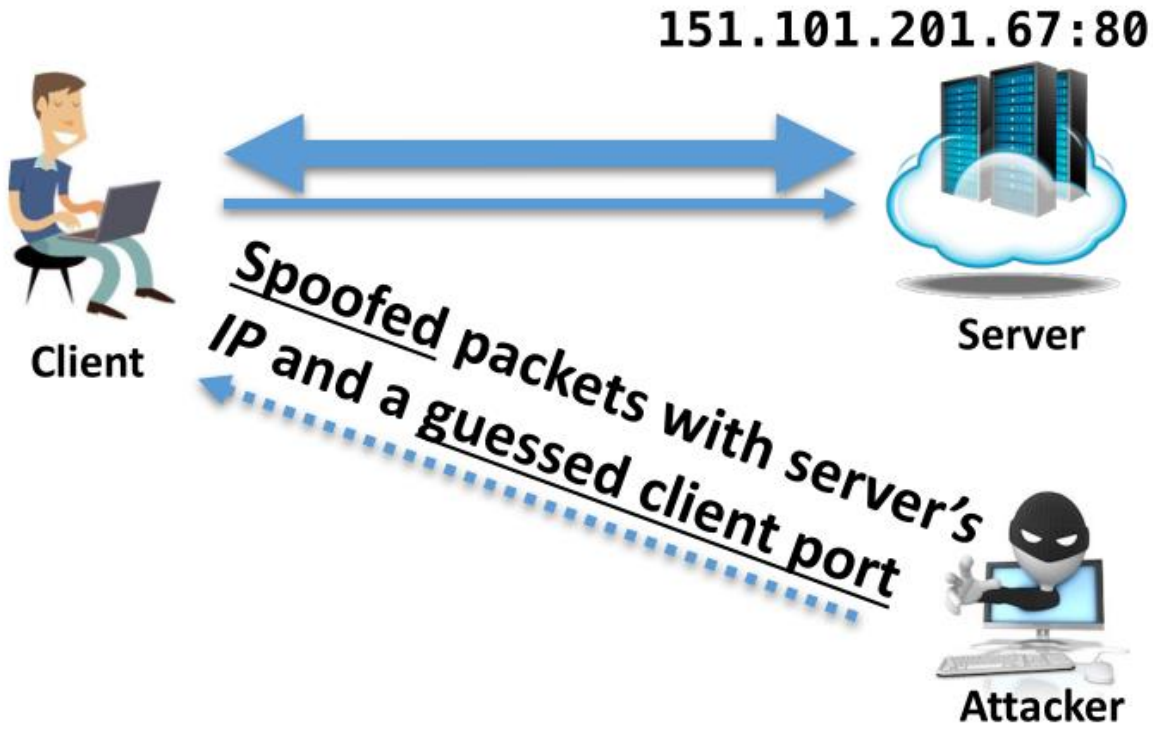



Connection identification
Not exist
Send RST
Exist
No
Set
SYN?
Rate-limited?
Send Challenge ACK
Not Set
Yes
Sequence number check
Out-of-window
RST?
Set
No
In-window
Discard
RST?
SEQ match?
Set
Not Set
Not Set
Yes
Reset the connection
Ack number check
Out-of-window
In-window
Accept
Send Duplicate ACK

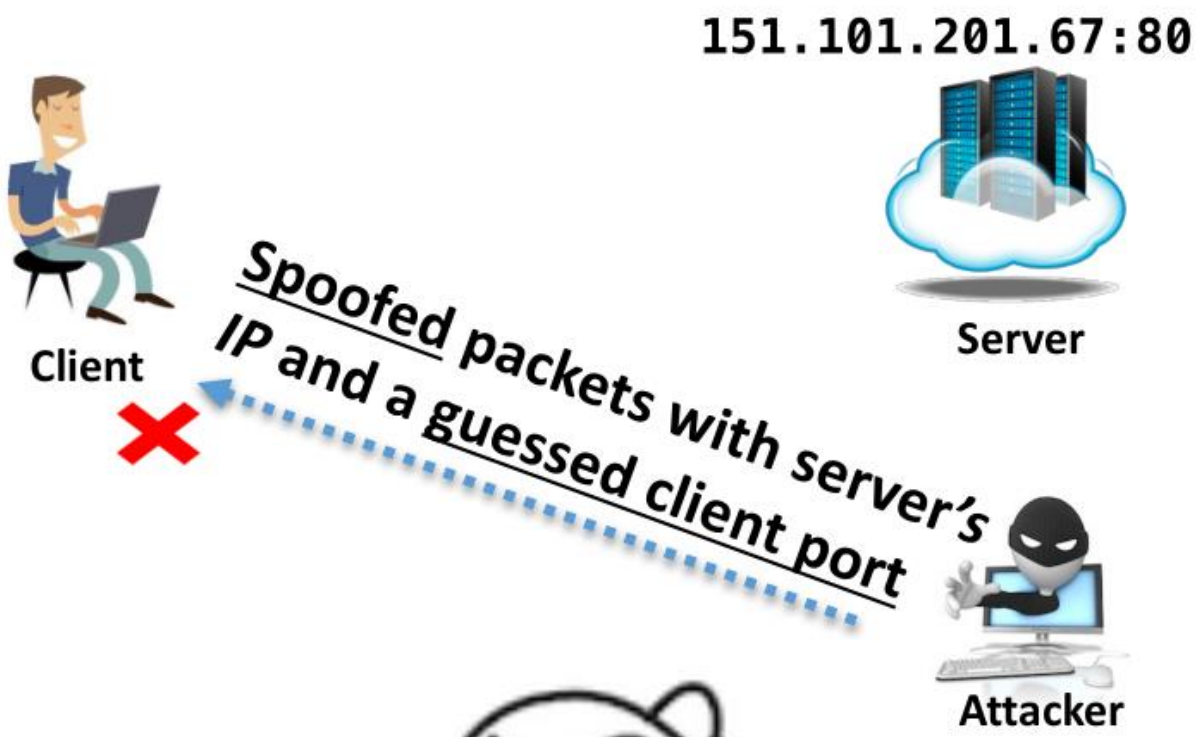

Connection identification
Not exist
Send RST
Exist
No
SYN?
Set
Rate-limited?
Send Challenge ACK
Not Set
Yes
Sequence number check
Out-of-window
RST?
Set
In-window
No
Discard
RST?
Set
SEQ match?
Not Set
Not Set
Yes
Reset the connection
Ack number check
Out-of-window
In-window
Accept
Send Duplicate ACK

Port Number Inference

Has connection

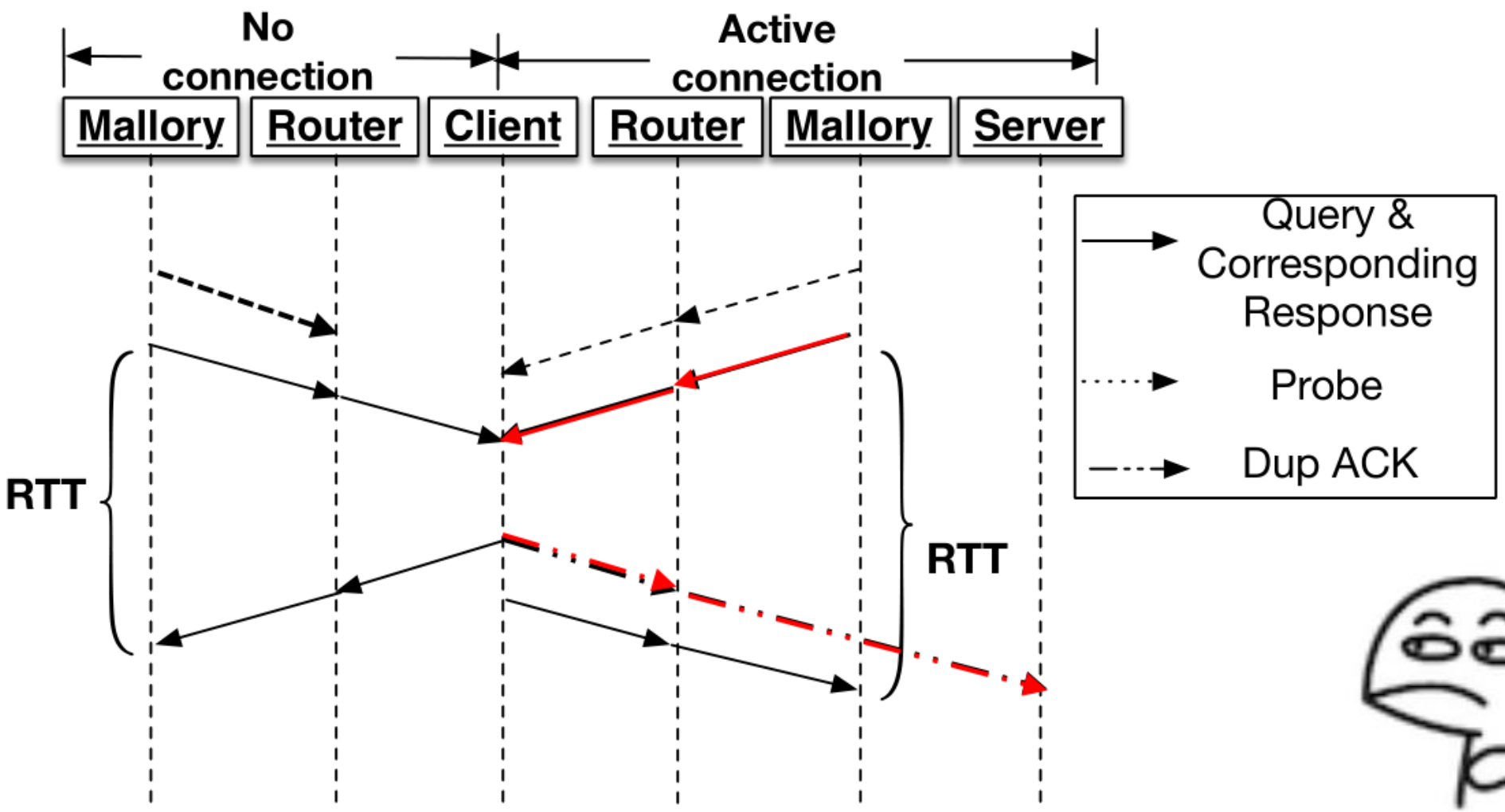


No connection



How can the attacker see the difference?

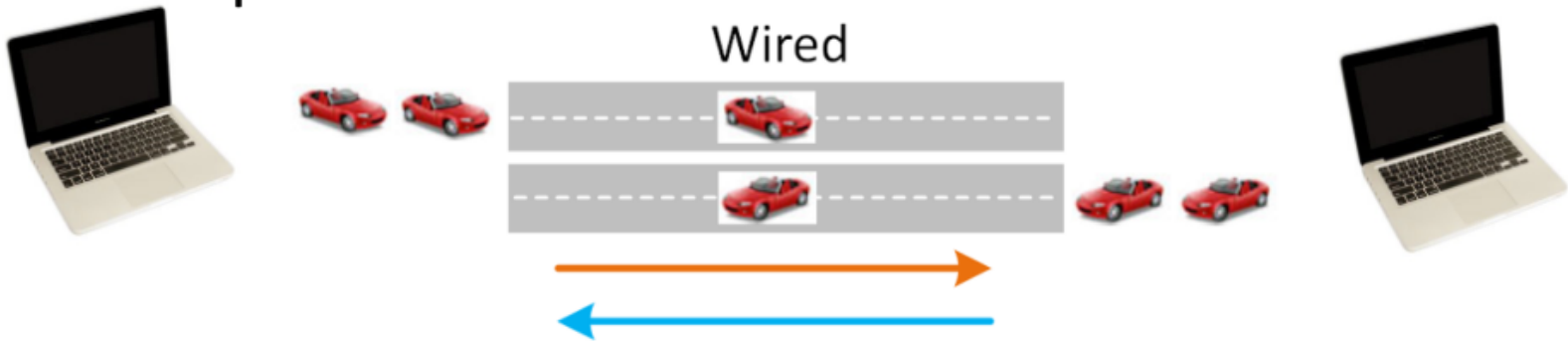
One Plausible Idea



Wireless Timing Channel

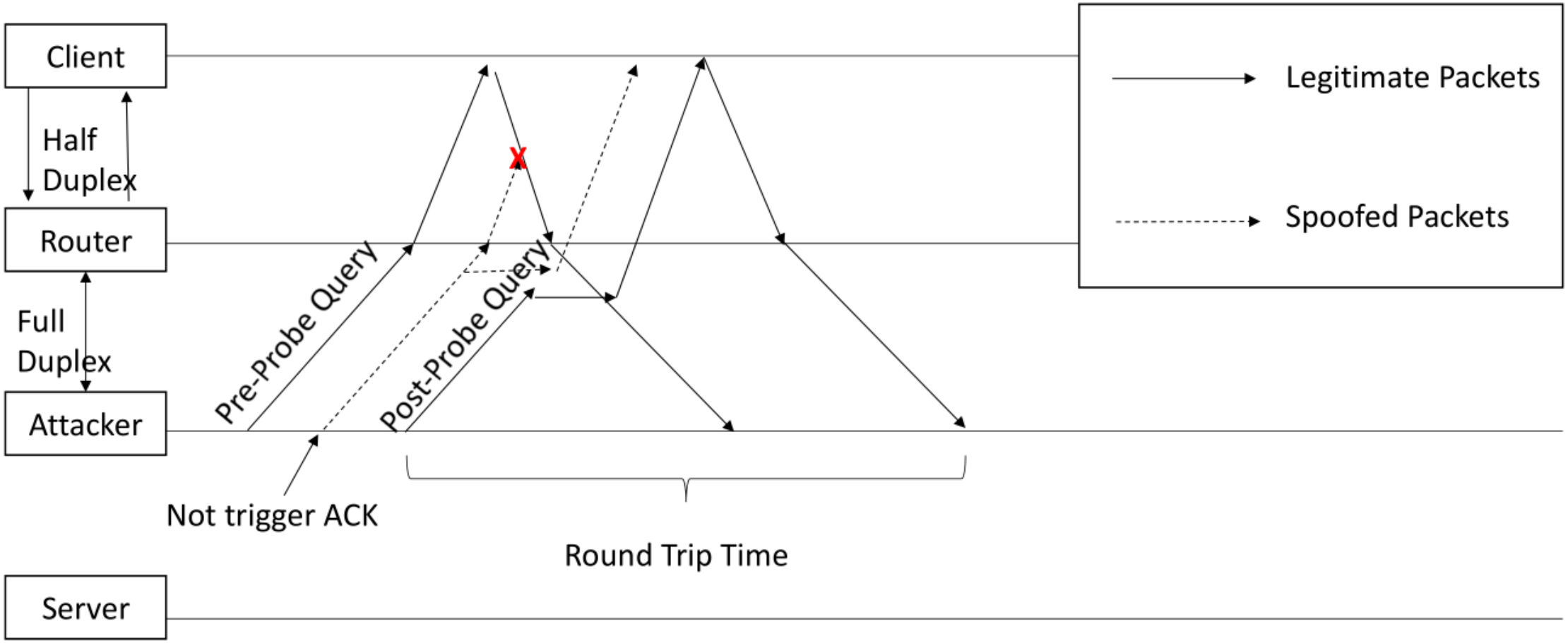
- **Half-duplex: A fundamental design of wireless protocol**
- **Shared Resource: The half-duplex wireless channel**

Full-duplex:

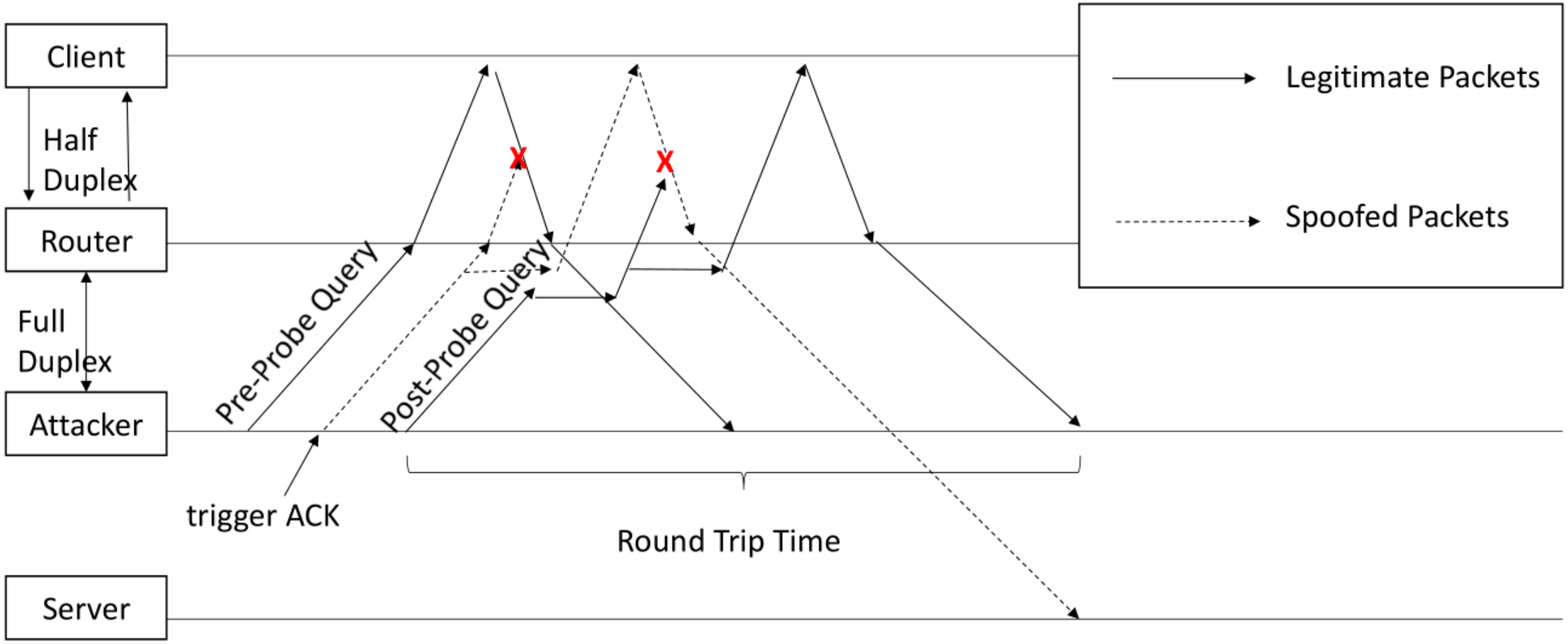


Half-duplex:

Probing Strategy



Probing Strategy (Cont)



Timing Difference

Client
Half Duplex
Router
Full Duplex
Attacker
Server

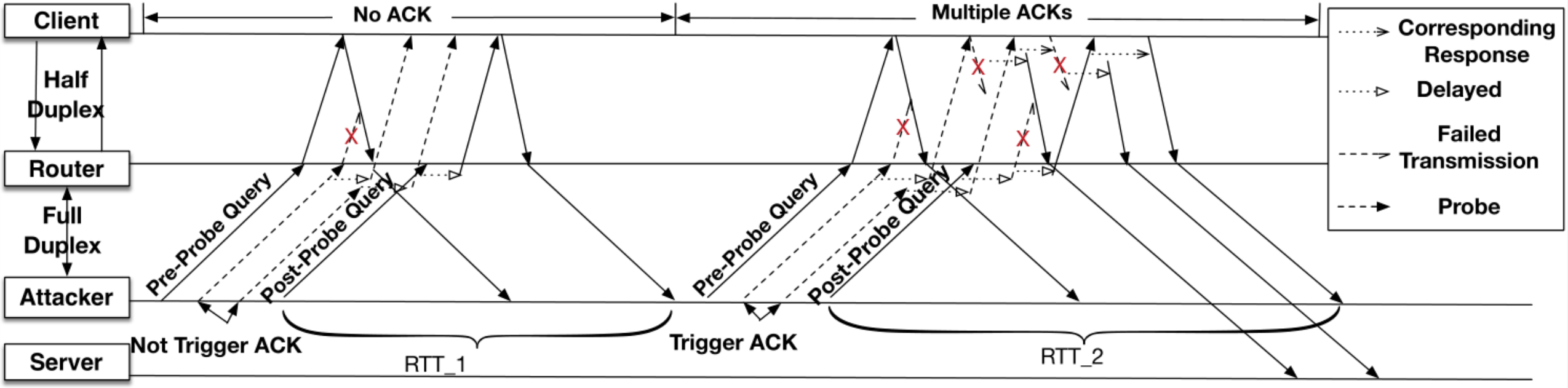
No ACKs
Triggering ACKs

Pre-Probe Query
Post-Probe Query
Not Trigger ACK
RTT_1
Pre-Probe Query
Post-Probe Query
Trigger ACK
RTT_2

Corresponding Response
Delayed
Failed Transmission
Probe

- **Larger RTT ➔ Trigger ACK ➔ Correct Port Number ?**

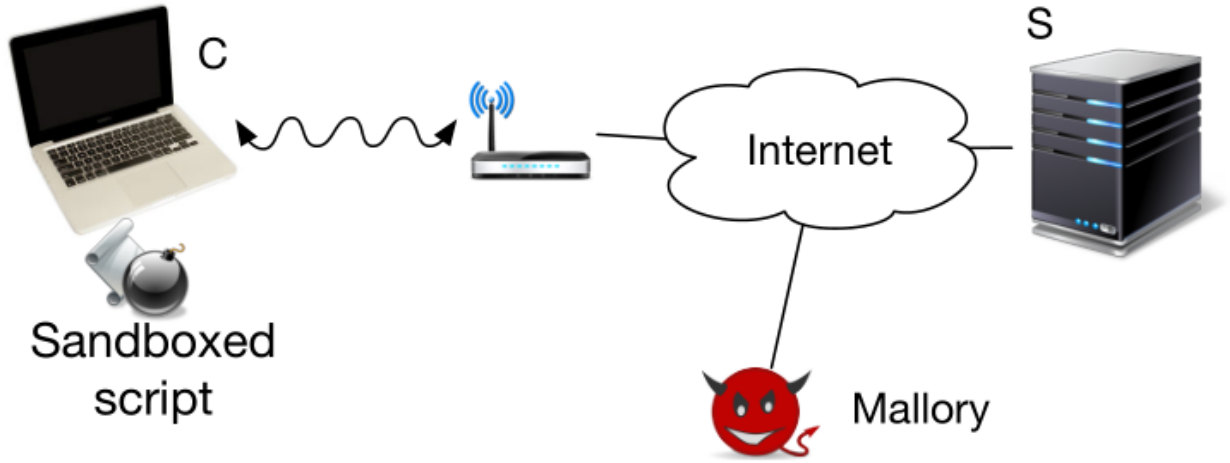
Timing Difference (Cont)



- **More Probing Packets ➔ More Contention ➔ Larger RTTS**

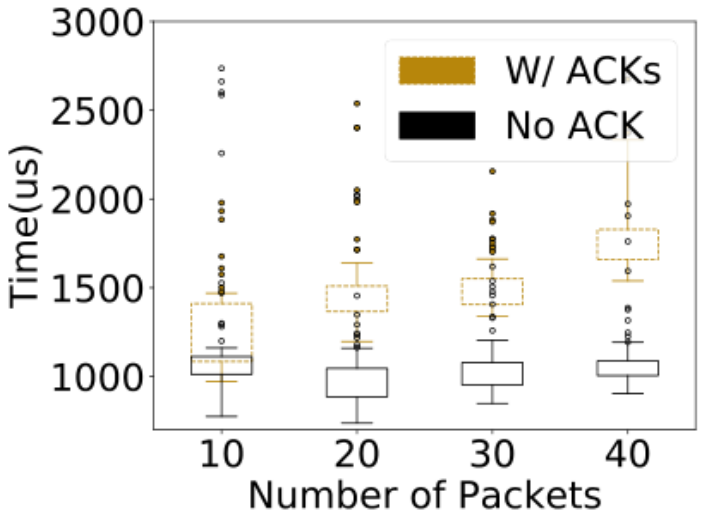
Empirical Test Results

- Setup:

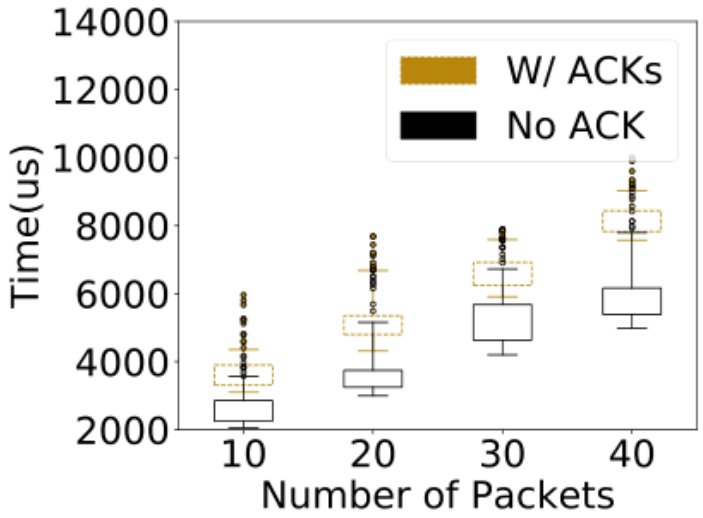


- 4 wireless routers: from Linksys, Huawei, Xiaomi, and Gee
- 2 machines: 2017 Macbook and 2017 Dell Desktop (Linux)
- 2.4GHz and 5GHz Wi-Fi

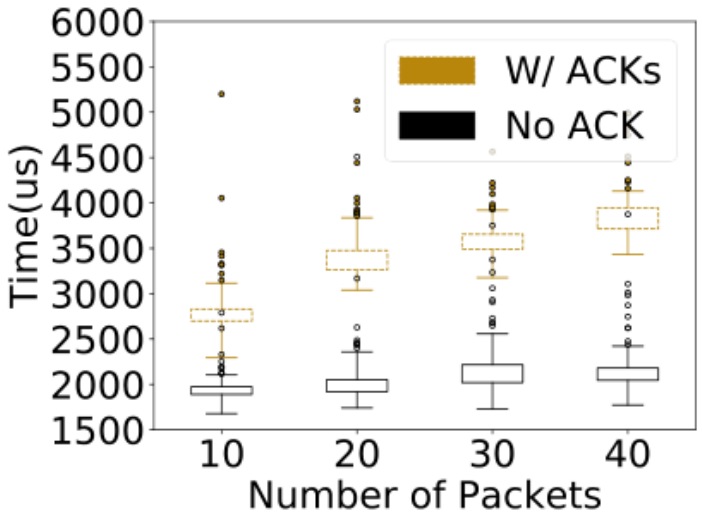
Empirical Test Results (Cont)



(a) RTT measurement of Linux using 5GHz network of a Linksys router

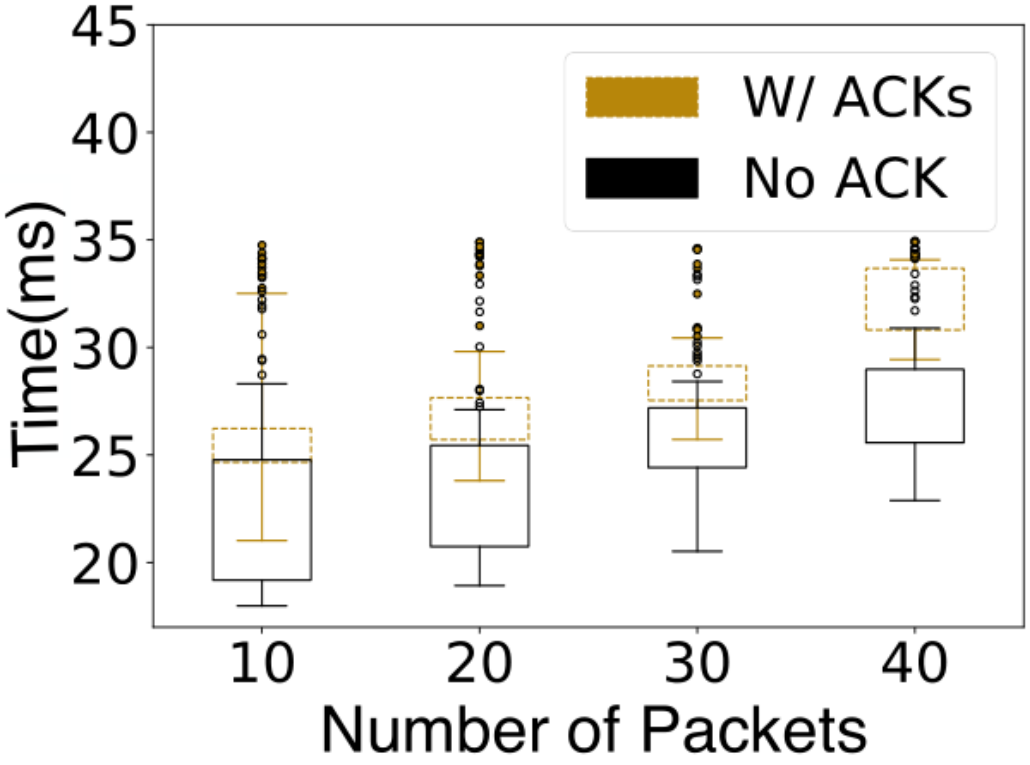


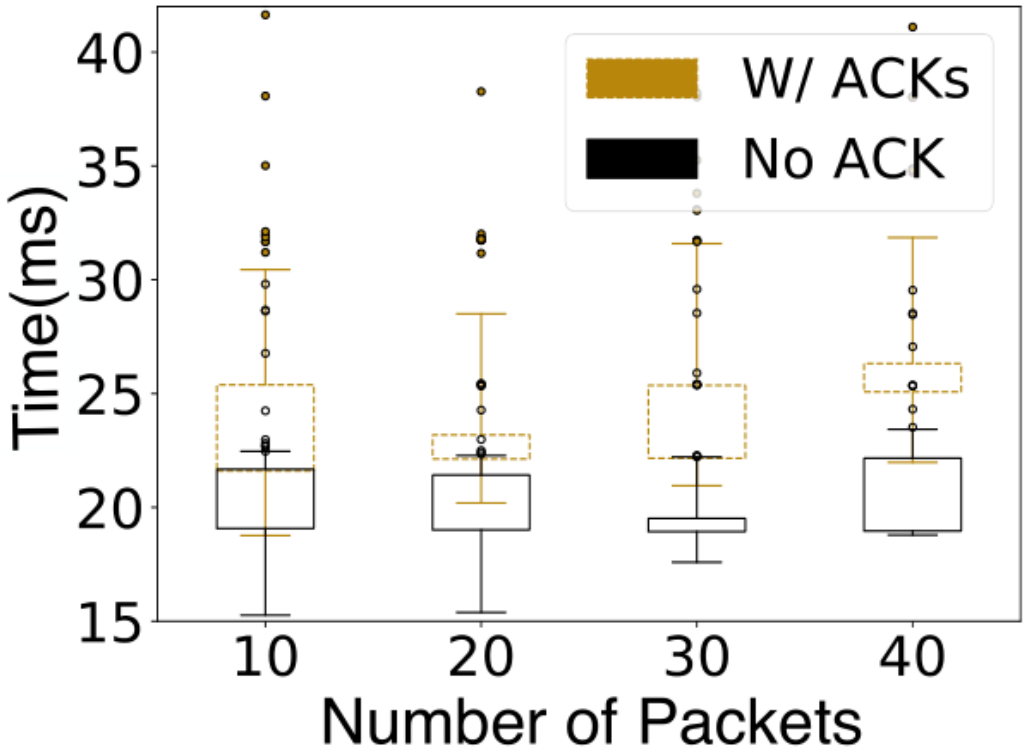
(b) RTT measurement of macOS using 2.4GHz network of a Xiaomi router



(c) RTT measurement of macOS using 5GHz network of a Huawei router

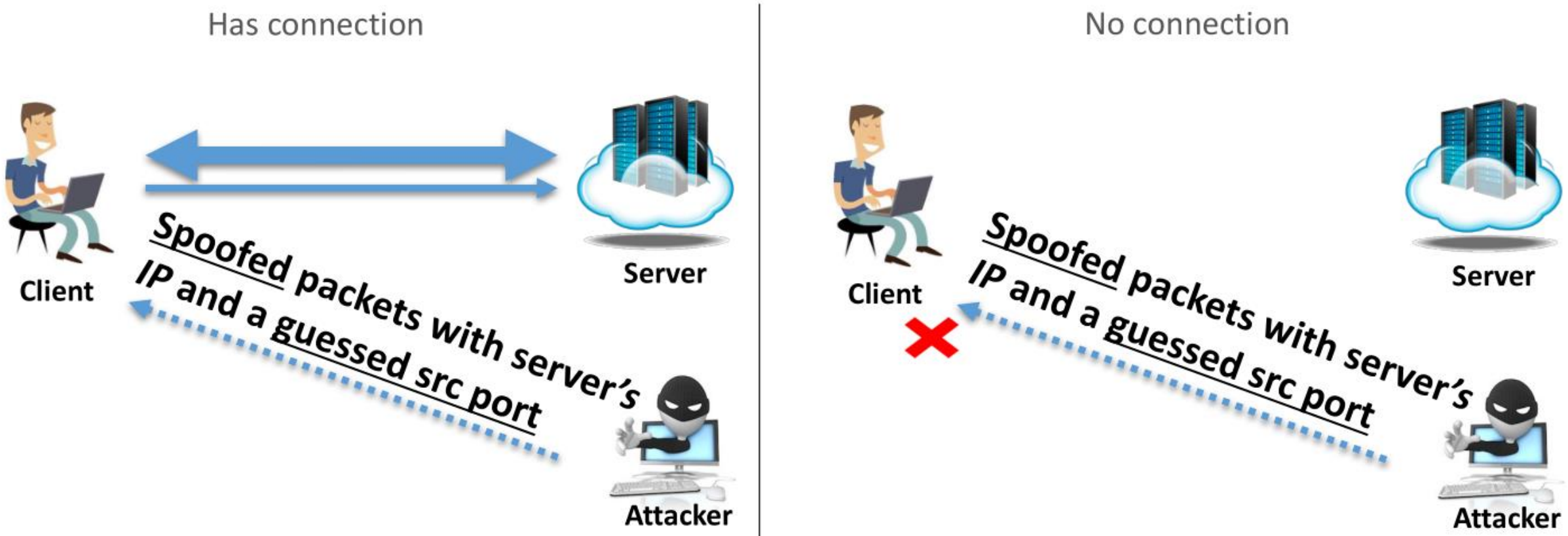
Empirical Test Results (Cont)





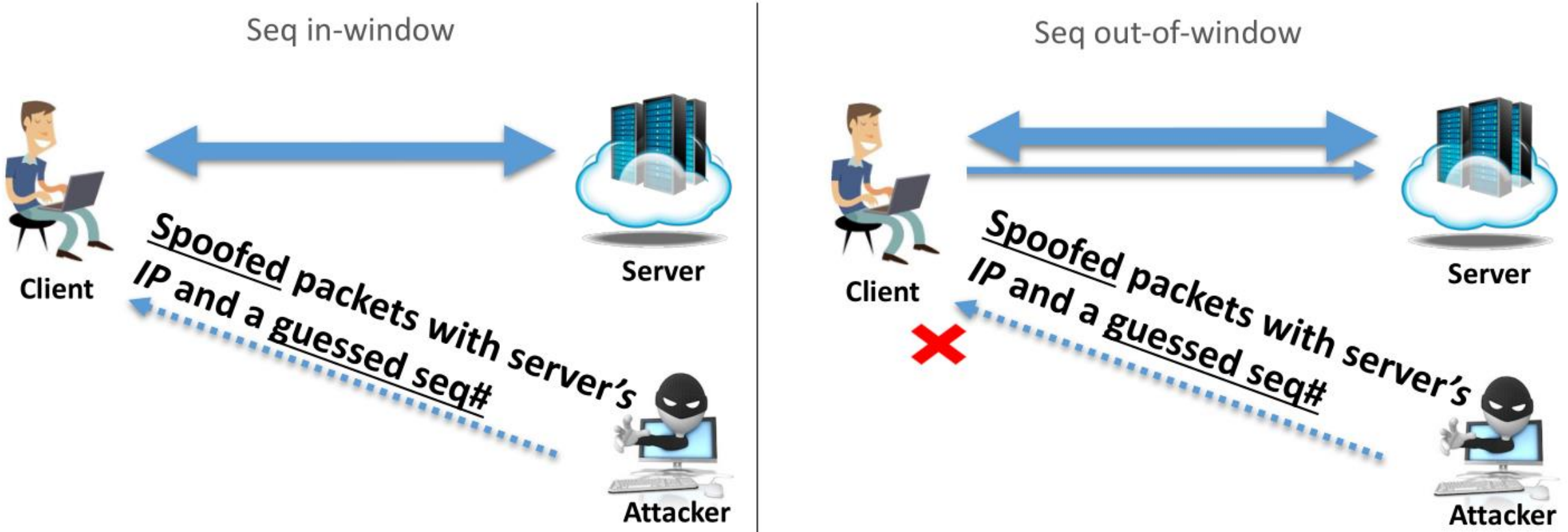
RTT measurement of macOS using 5GHz network of a Xiaomi router at two different locations with RTTs over 20ms

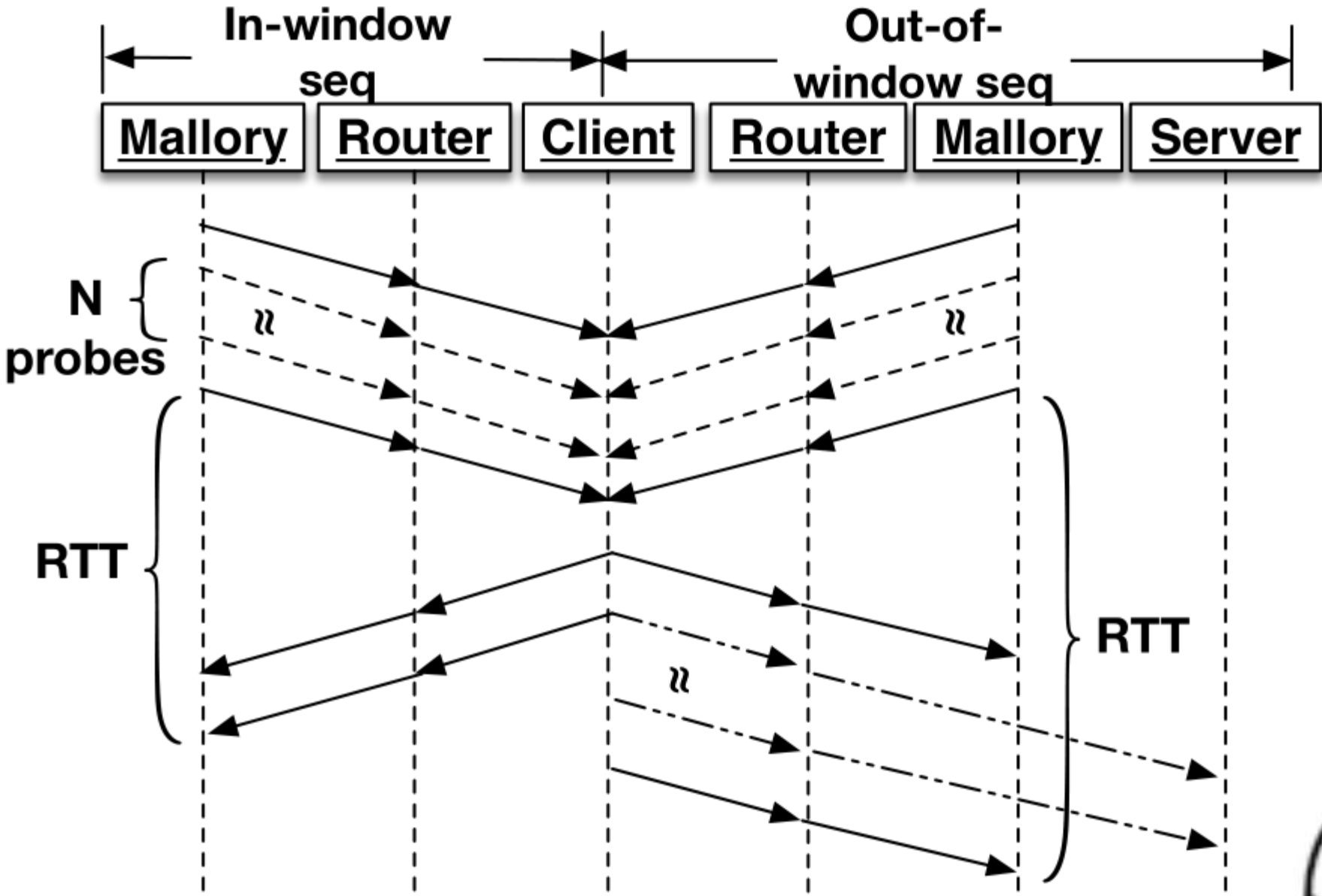
Port Number Inference



How can the attacker see the difference?

Sequence Number Inference





(b) Sequence number test

TCP Stack Implementations

No.	OS	FLAG	SEQ	ACK	PAYLOAD	#Responses
1	Linux	ACK|SYN|RST	Out-of-window	Any	1	10
3	Linux	ACK|SYN|RST	In-window	> SND.MAX	Any	0
10	MacOS	None|ACK	Out-of-window	Any	Any	10
11	MacOS	None	In-window	Out-of-window	Any	0
17	Windows	ACK|FIN|SYN	Out-of-window	Any	Any	10
18	Windows	ACK|FIN	In-window	Out-of-window	Any	0

Table. Behaviors on different OSes when processing 10 identical packets*

*:See the complete table in our paper

ACK Number Inference

- Implementations of ACK number check varies significantly from one OS to another
- Exploit HTTP specifications and behaviors of tolerant browsers
  - Brute-force ACK number
- Only takes a couple of seconds

Evaluation

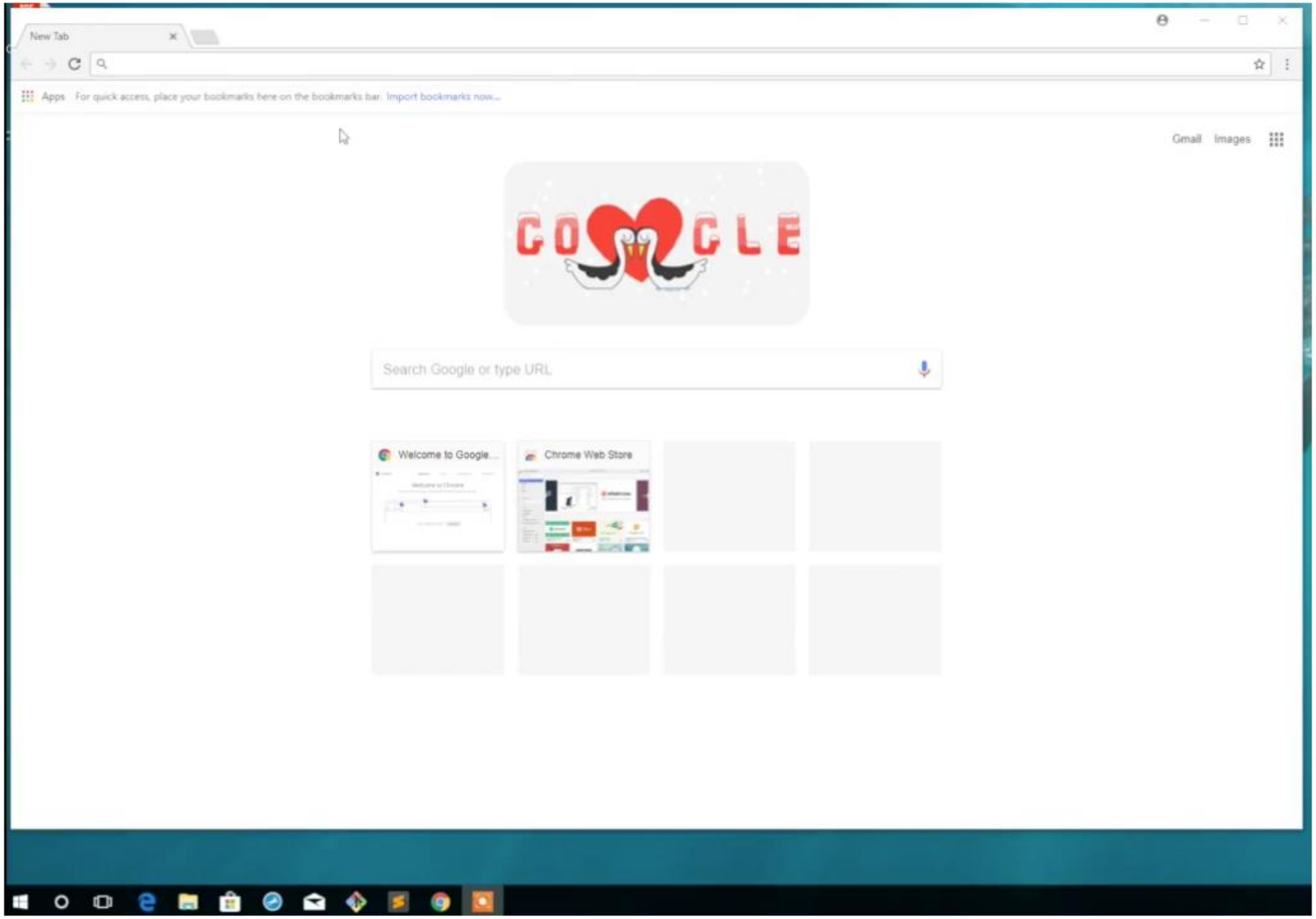
OS	Browser	Success Rate	Avg time cost (s)
Linux	Chrome/Firefox	10/10	188.80
MacOS	Chrome/Firefox	10/10	48.91
Windows	Chrome/Firefox	10/10	43.42

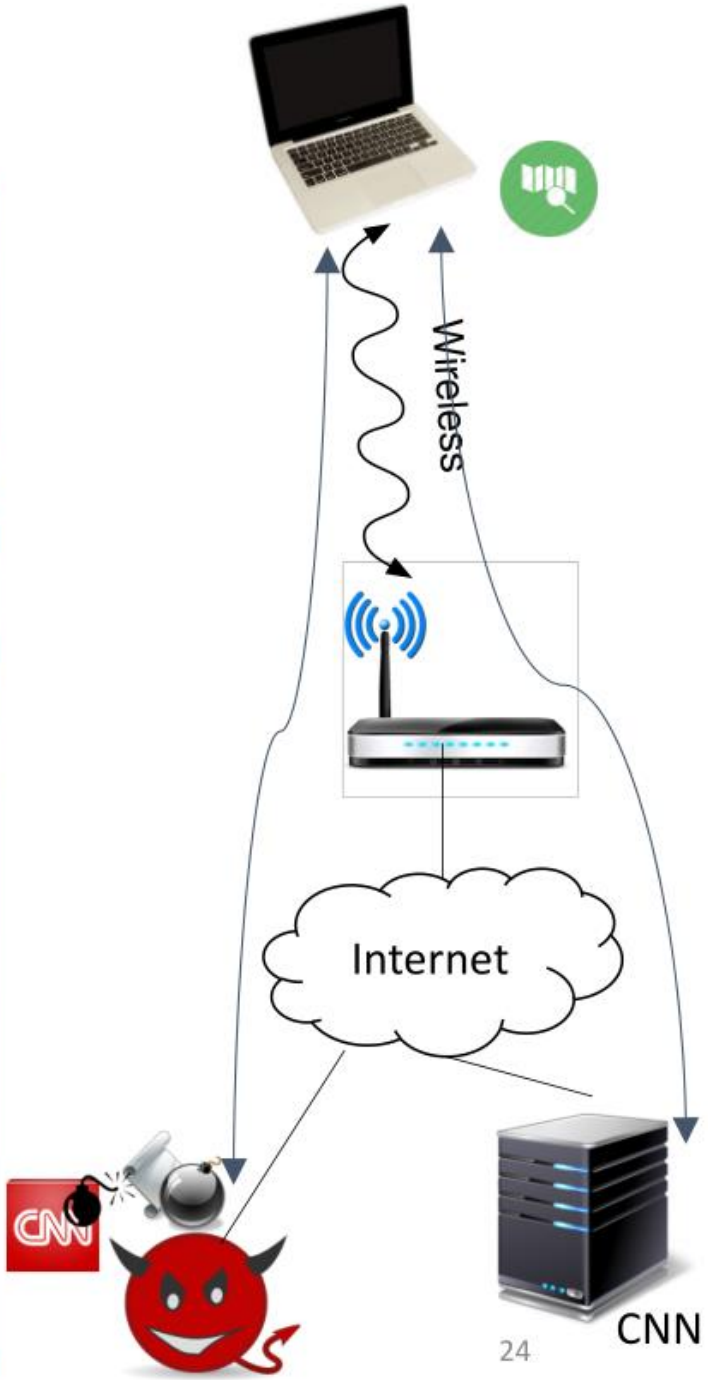
Local result

OS	Browser	Success Rate	Avg time cost (s)
MacOS	Chrome/Firefox	9/10	304.18

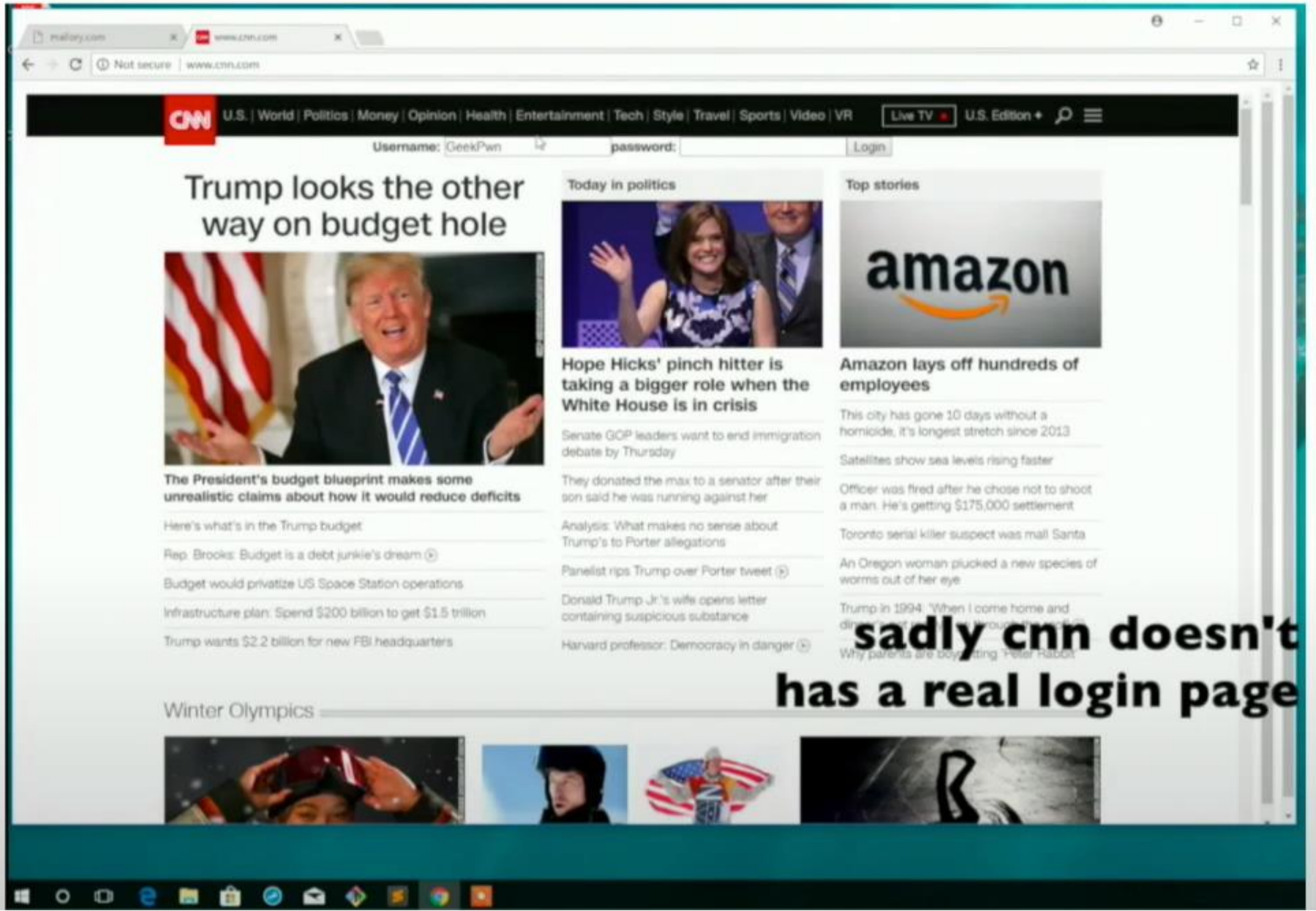
Remote result (RTT = 20ms)

Demo: Web Cache Poisoning

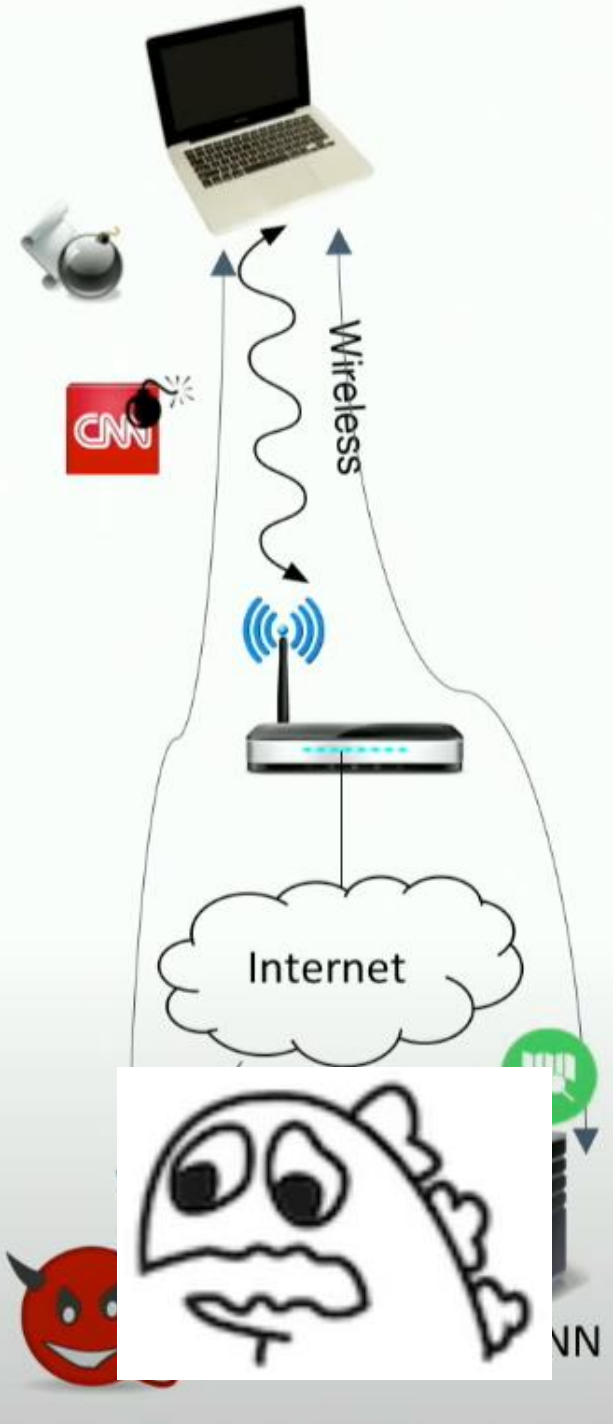




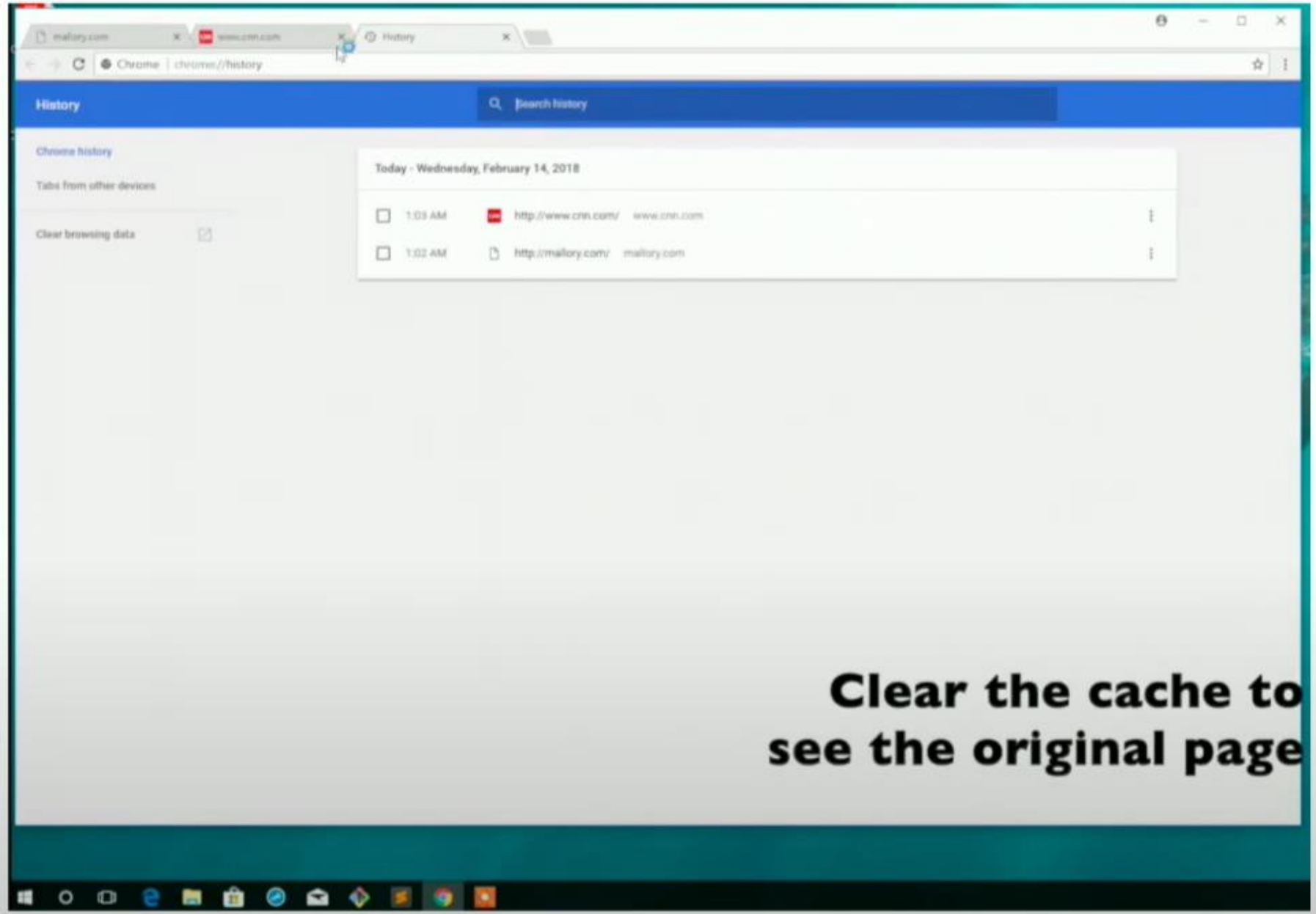
Demo: Web Cache Poisoning

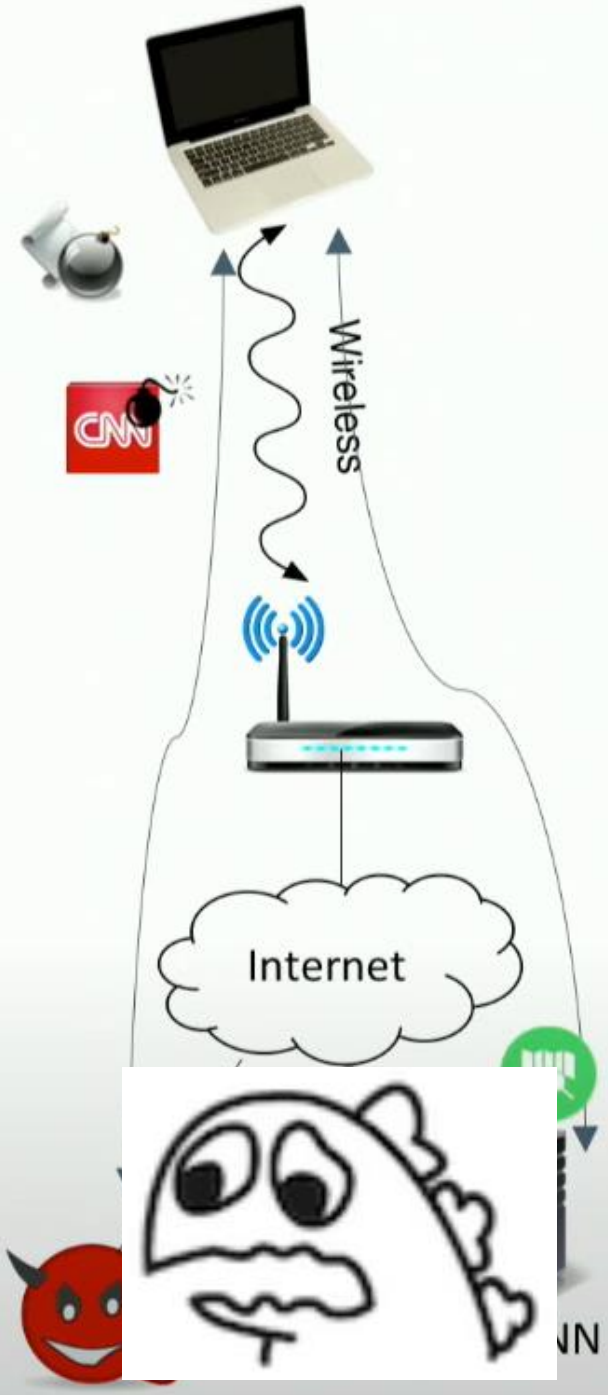


sadly cnn doesn't has a real login page

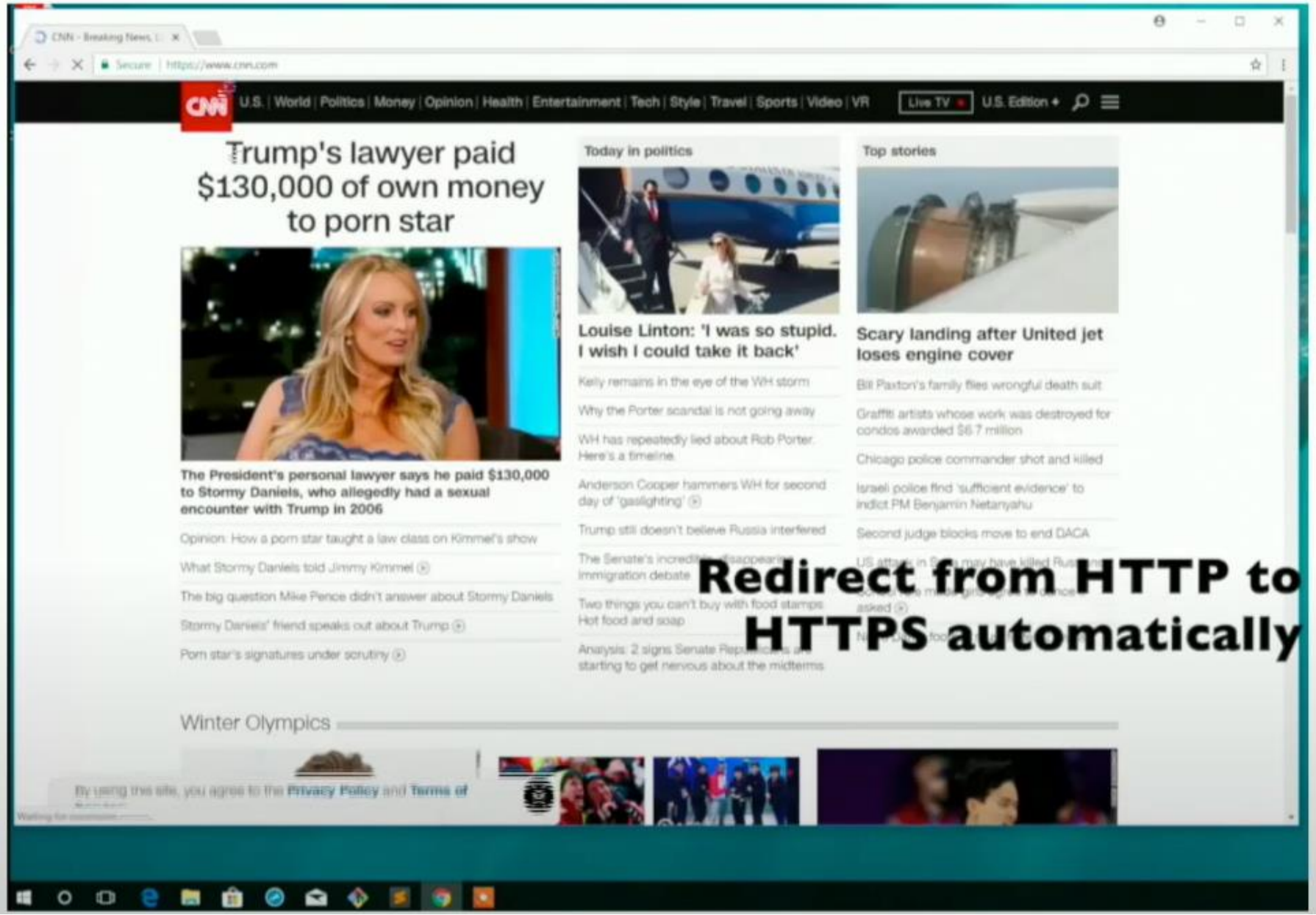


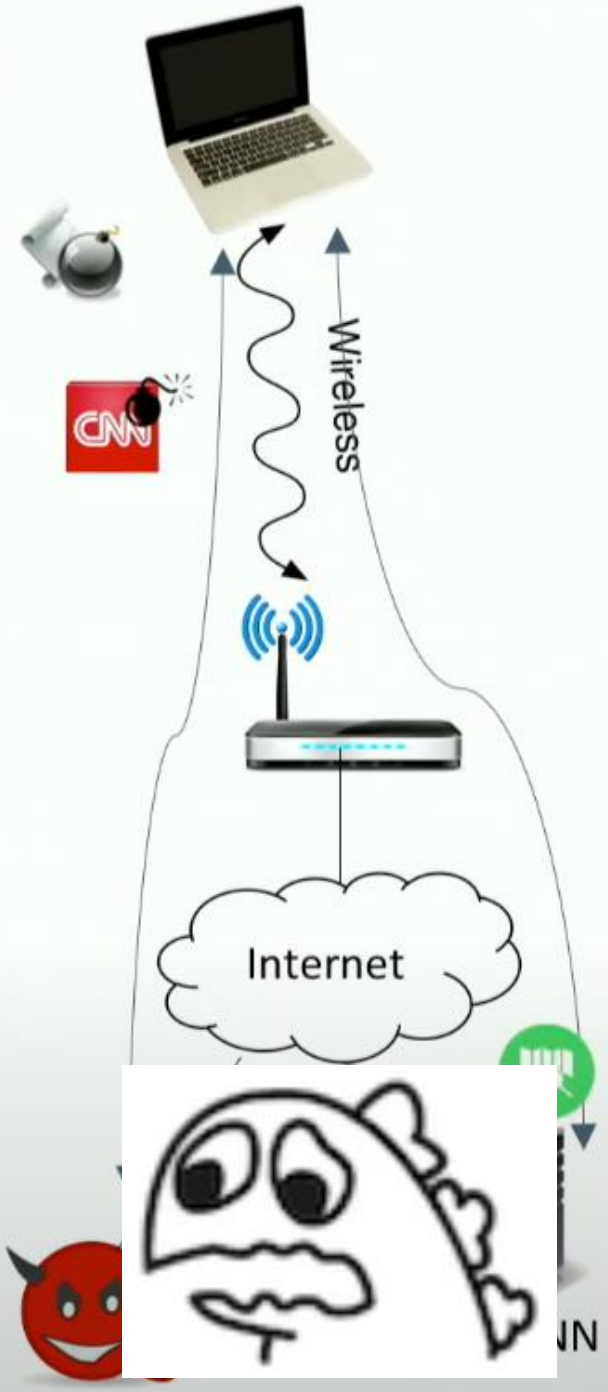
Demo: Web Cache Poisoning



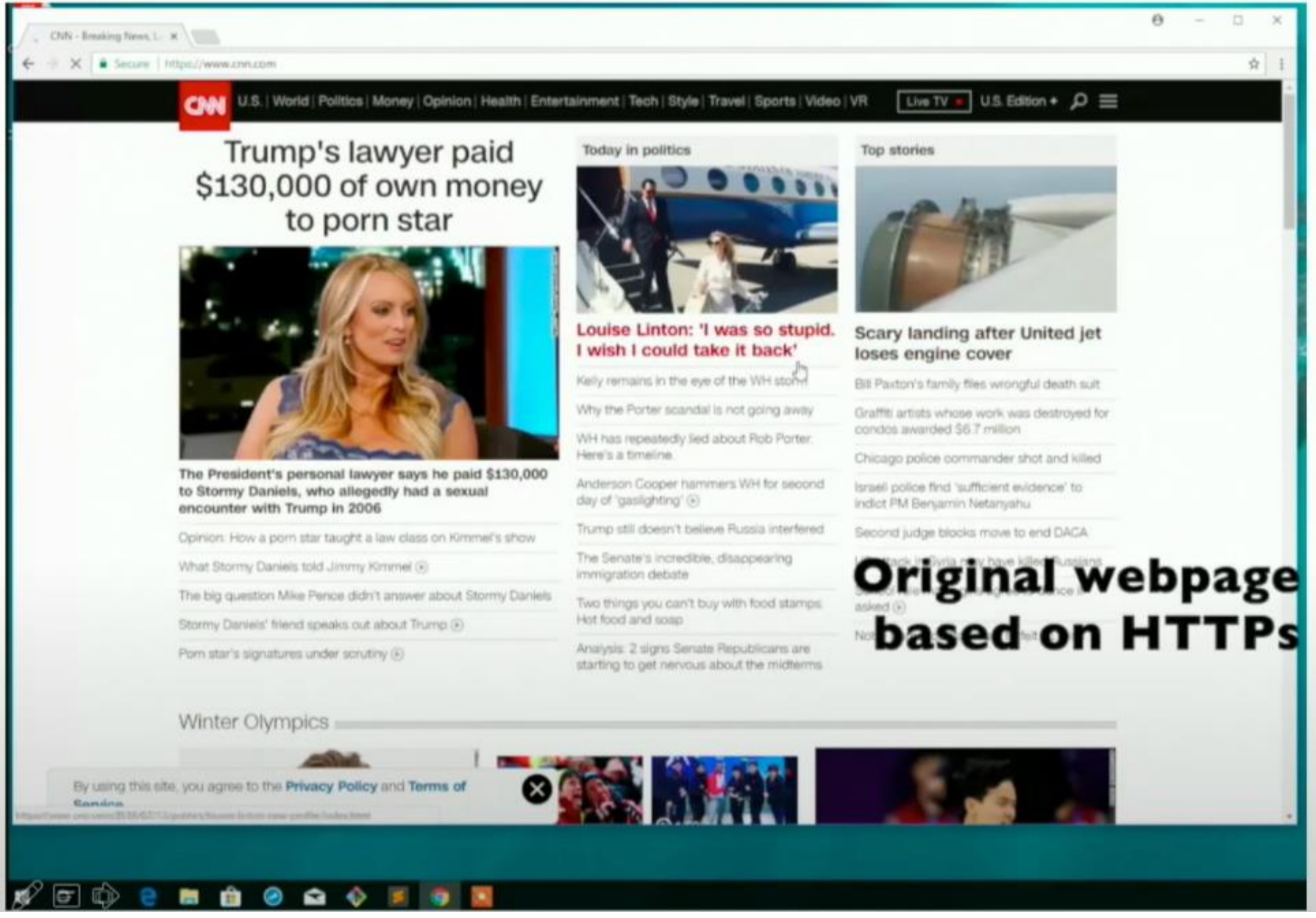


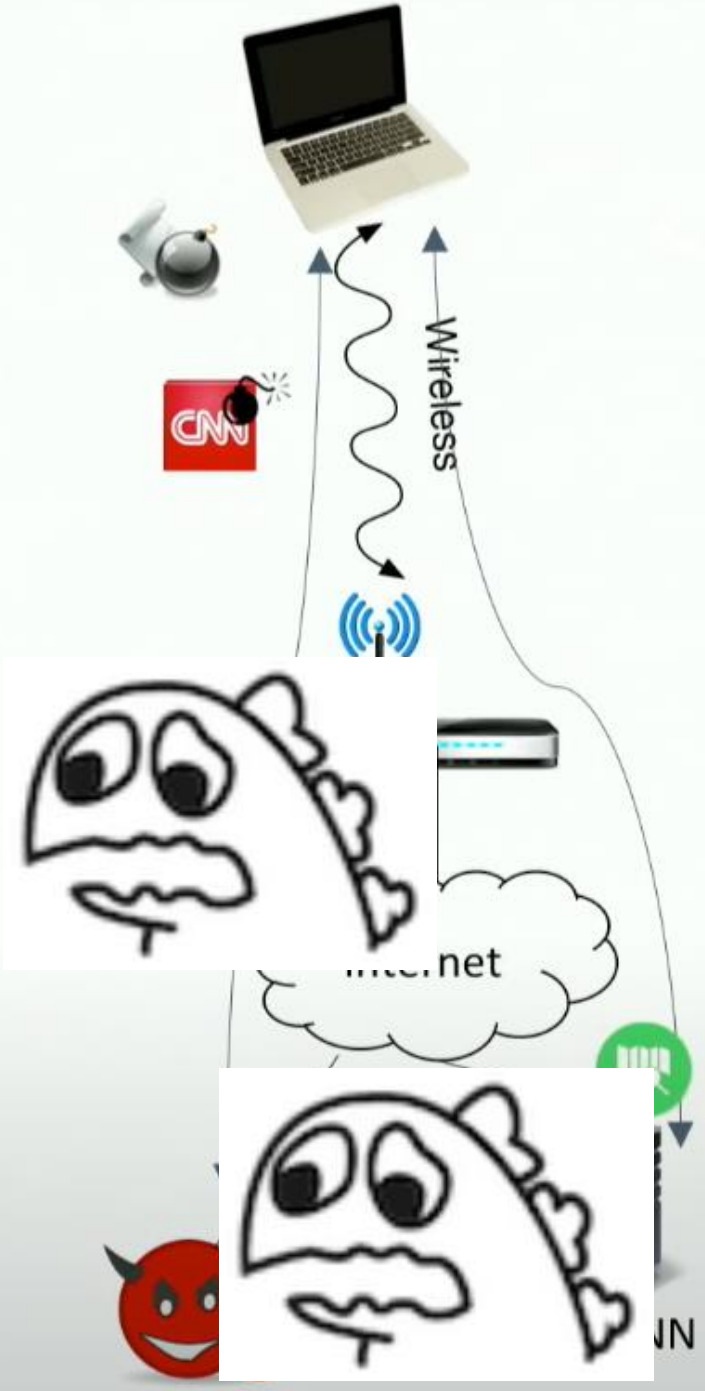
Demo: Web Cache Poisoning





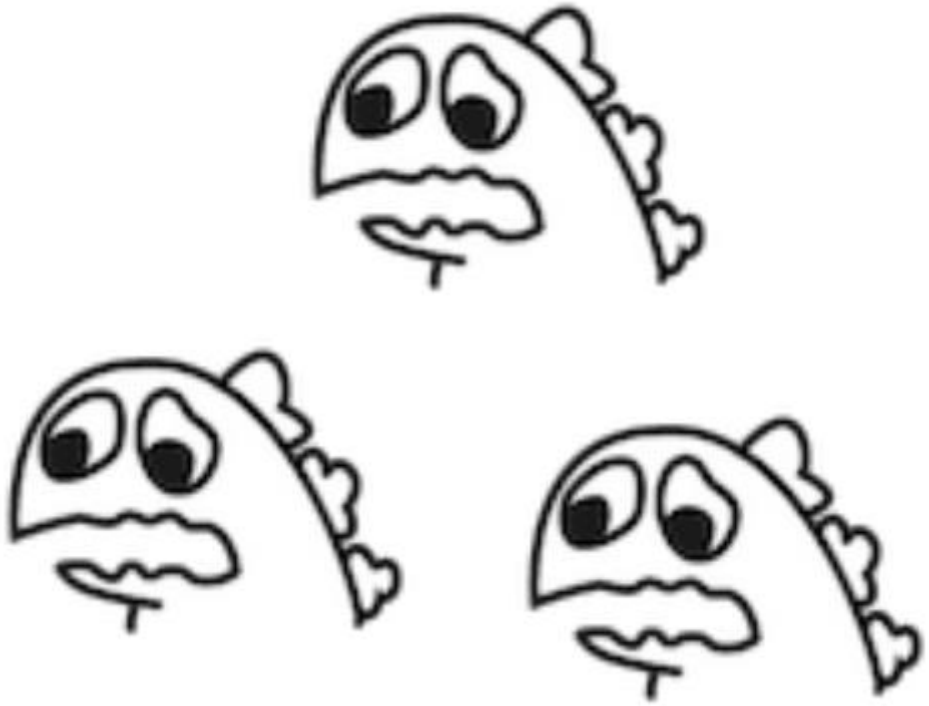
Demo: Web Cache Poisoning





How bad?

- Teleconference with IEEE 802.11 working group
- **It’s not possible to be fixed at physical and MAC layers!**



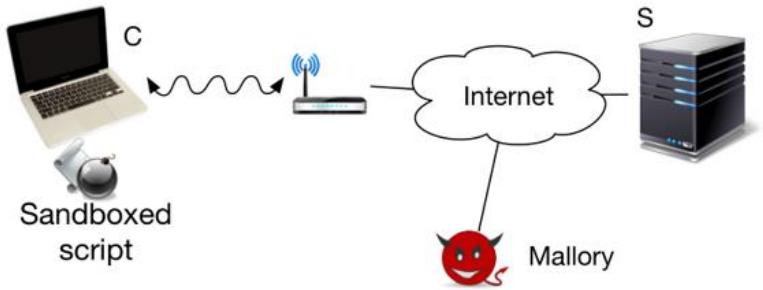
Defenses/Mitigations

- Wireless Layer: Full-duplex Wi-Fi Technology
  - E.g., Frequency-division duplexing, different frequency sub-bands
- TCP Stack: Revisit TCP Specifications
  - E.g., Rate limit responses for incoming packets with out-of-window SEQ
- Application Layer: Deploy HSTS (HTTP Strict Transport Security)
  - Preventing access via the insecure HTTP protocol

Conclusion

- A new timing side channel inherent in all generations of IEEE 802.11 or Wi-Fi technology
- Comprehensive analysis of TCP stack implementations in macOS, Windows, and Linux
- Implement practical TCP injection attacks
- Propose possible defenses
- https://github.com/seclab-ucr/tcp_exploit

Off-Path TCP Exploit: How **Wireless Routers** Can Jeopardize Your Secrets



Weiteng Chen, Zhiyun Qian

University of California, Riverside